



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

BSI TR-03188: Technische Richtlinie Passkey Server

Sicherheits- und Handlungsempfehlung



Änderungshistorie

<i>Version</i>	<i>Datum</i>	<i>Name</i>	<i>Beschreibung</i>
1.0	15.06.2026	BSI	Erstfassung

Tabelle 1: Beschriftung

Inhalt

1	Einleitung	5
2	Grundlagen	7
2.1	Definitionen und Begrifflichkeiten	7
2.2	Berücksichtigte Versionen von Spezifikationen und Richtlinien	9
3	Sicherheitsempfehlung	10
3.1	FIDO Security Reference	10
3.1.1	Protokollparteien	10
3.1.2	Sicherheitsrelevante Annahmen	11
3.1.3	Sicherheitsziele	11
3.1.4	Bedrohungen	12
3.2	Angreifermodelle	14
3.2.1	Angreifermodell 0 (AM-0)	14
3.2.2	Angreifermodell 1 (AM-1)	15
3.2.3	Angreifermodell 2 (AM-2)	16
3.2.4	Angreifermodell 3 (AM-3)	17
3.2.5	Angreifermodell 4 (AM-4)	17
3.2.6	Angreifermodell 5 (AM-5)	19
3.2.7	Angreifermodell 6 (AM-6)	19
3.3	Vertrauensniveaus	21
3.4	Sicherheitsmechanismen	22
3.4.1	Vertrauensniveau normal	23
3.4.2	Vertrauensniveau substantiell	26
3.4.3	Vertrauensniveau hoch	28
3.5	Weitere Aspekte	30
3.5.1	Nicht berücksichtigte Konfigurationsoptionen	30
3.5.2	Sicherheits- und Datenschutzüberlegungen	31
3.5.3	Übersicht über die FIDO-Extensions	35
4	Handlungsempfehlung	38
4.1	Integrationsmöglichkeiten	38
4.2	Gegenüberstellung der verschiedenen Integrationsmöglichkeiten	39
4.2.1	Aufwand der Integration	39
4.2.2	Konfigurierbarkeit	40
4.2.3	Funktionsumfang	40
4.2.4	Flexibilität	41
4.2.5	Sicherheitsaspekte	41
4.2.6	Preisgestaltung und Kosten	42

4.2.7	Interoperabilität und Integration in bestehende Infrastruktur	42
4.2.8	Referenzen	43
4.2.9	Zusammenfassung	44
4.3	Empfehlung	47

1 Einleitung

Seit Beginn der modernen IT werden Passwörter als zentraler Mechanismus zur Authentisierung verwendet. In der Praxis gibt es bei der Verwendung von Passwörtern allerdings zahlreiche Sicherheitsherausforderungen. So können beispielsweise kurze Passwörter mit geringer Komplexität oder mit leicht vorhersehbaren Zeichenfolgen (bspw. Geburtstage) – wie sie sich Menschen leicht merken können – von Angreifenden schnell automatisiert erraten werden (Brute Force). Ebenso neigen Menschen dazu, einmal auswendig gelernte Passwörter für mehrere Dienste wiederzuverwenden. Wird einer dieser Dienste von Angreifenden kompromittiert, können sie dann die gestohlenen Passwortinformationen zur Authentisierung bei weiteren Diensten nutzen (Credential Stuffing). Angreifende können Nutzende außerdem leicht dazu bewegen, ihr Passwort auf einer durch die Angreifenden kontrollierten Webseite einzugeben, die der eigentlichen Seite optisch gleicht (Phishing) und so auch komplexe, individuelle Passwörter in Erfahrung bringen.

Um diesen Angriffen zu begegnen, wurde das Konzept der „Mehrfaktorauthentisierung“ (MFA) entwickelt. Bei einer MFA müssen für einen Authentisierungsvorgang mehrere, verschiedenartige Nachweise erbracht werden. Eine Ausprägung davon sind Passwörter in Kombination mit einem zeitbeschränkten Einmalcode (One Time Password). Auch die Verwendung von MFA adressiert jedoch noch nicht alle gängigen Angriffsvektoren auf Passwörter. So sind alle gängigen Verfahren, die auf One Time Passwords basieren, anfällig gegenüber komplexeren Phishing-Angriffen, bei denen Angreifende abgefangene Authentisierungsinformationen in Echtzeit zur Authentisierung nutzen (Real Time Phishing).

Forschende im Bereich IT-Sicherheit sowie zentrale Akteure in unserer modernen IT-Landschaft arbeiten daher schon seit Jahren daran, Passwörter als Authentisierungsmechanismus abzulösen. Eine der vielversprechendsten Ansätze dafür sind die sogenannten Passkeys. Diese Passkeys basieren nicht auf der Übermittlung eines festen, statischen Werts (wie bspw. ein Passwort), sondern auf einem bekannten Challenge-Response-Verfahren, bei dem Nutzende eine Nachricht mitsamt einem von der Gegenseite übermittelten und zufällig generierten, komplexen Einmalwert kryptographisch signieren. Durch Prüfung der Signatur kann dann die Identität der Nutzenden nachvollzogen werden. Ein großer Vorteil von Passkeys ist, dass sie resistent gegenüber skalierbaren Phishing-Angriffen sind. Darüber hinaus besitzen Passkeys ein hohes Maß an Usable Security, da sie in unterschiedlichen Ausprägungen verfügbar sind und somit auch für unterschiedliche Einsatzzwecke genutzt werden können.

Passkeys werden im Rahmen der US-amerikanischen FIDO-Allianz (Fast IDentity Online) entwickelt und basieren auf der FIDO2-Protokollfamilie. Diese Protokollfamilie standardisiert und spezifiziert die technischen Schnittstellen und Abläufe, sowie sicherheitstechnische Voraussetzungen, die eine Authentisierung mittels Passkeys möglich machen. Das betrifft unter anderem die kryptographischen Verfahren, die Speicherung des kryptographischen Schlüsselmaterials im sogenannten „Authenticator“, die Verarbeitung und Weiterleitung der Authentifizierungsanfragen im Browser (Client To Authenticator Protocol/CTAP) und die Anfrage von Authentisierungsnachweisen durch den Dienst (Relying Party, RP) über die von der W3C veröffentlichte Web Authentication API (WebAuthn).

FIDO2 sieht zwei Arten von Authenticators vor: „platform“ und „roaming“. Ein Platform Authenticator ist dabei fest an ein spezifisches Hostsystem gebunden und kann auch nur dort zur Durchführung eines Authentisierungsvorgangs verwendet werden. Ein Beispiel dafür ist die FIDO2-Implementierung im Rahmen von „Windows Hello“, bei der das relevante Schlüsselmaterial im TPM (Trusted Platform Module) des Computers gespeichert wird. Im Gegensatz dazu sind Roaming Authenticator transportable und ortsunabhängige Hardwaregeräte, auf denen das kritische Schlüsselmaterial sicher und vertraulich verwendet werden kann. Die „FIDO Security Reference“ und die „FIDO Authenticator Security Requirements“ definieren strenge Anforderungen an die Sicherheit von allen Arten von Authenticators.

Passkeys lassen sich in zwei Kategorien unterteilen. Zum einen gibt es Synced Passkeys, bei denen das Schlüsselmaterial (verschlüsselt) in Cloud-Speicherdiensten abgelegt und somit zwischen verschiedenen

Authenticators synchronisiert werden kann. Zum anderen gibt es Device Bound Passkeys, bei denen das Schlüsselmaterial an ein bestimmtes Gerät gekoppelt bleibt.

In der Praxis hat sich bisher keines der beiden Passkey-Formen gegenüber anderen Verfahren durchgesetzt, da Webseitenbetreibende vor zahlreichen Herausforderungen bei der Implementierung von FIDO2 stehen. Schließlich bietet die WebAuthn-Spezifikation der Relying Party verschiedene Konfigurationsoptionen und Erweiterungen an, deren Verwendung jeweils einen Einfluss auf die Sicherheit des Authentisierungsvorgangs hat. Beispielsweise können Authenticators überprüft und so die Nutzung bestimmter Authenticators eingeschränkt werden.

Im Rahmen dieser Technischen Richtlinie (BSI TR-03188) werden die unterschiedlichen Nutzungs- und Implementierungsarten von Passkey Servern (FIDO2 Server) und insbesondere die Konfigurationsmöglichkeiten, die die WebAuthn-Spezifikation bietet, systematisch erfasst und analysiert. Die sich daraus ergebende **Sicherheitsempfehlung** enthält konkrete Maßnahmen zur Gewährleistung der Sicherheit des Authentisierungsvorgangs auf unterschiedlichen Vertrauensniveaus. Vorrangiges Ziel ist es, Webseitenbetreibende in die Lage zu versetzen, eigenständig informierte Entscheidungen über die sichere Konfiguration eines Passkey Servers treffen zu können.

Des Weiteren enthält diese TR eine Gegenüberstellung der Integrationsmöglichkeiten für Passkey Server. Ziel ist es, neben der Sicherheitsempfehlung ebenfalls eine **Handlungsempfehlung** bereitzustellen, die Webseitenbetreibende bei der Auswahl einer geeigneten Integrationslösung für Passkey Server auf ihren Webseiten unterstützt. Beide Empfehlungen sollen dazu beitragen, dass die Beurteilungsfähigkeiten bei der serverseitigen Einführung von Passkeys gestärkt und die dazugehörigen Lösungskompetenzen gesteigert werden.

2 Grundlagen

2.1 Definitionen und Begrifflichkeiten

In diesem Abschnitt werden wichtige WebAuthn- bzw. FIDO2-spezifische Begriffe definiert.

<i>Begriff</i>	<i>Definition</i>
AAGUID	Die Authenticator Attestation Globally Unique ID (AAGUID) identifiziert eindeutig die Marke (Hersteller) und das Modell des Authenticators.
Assertion	Bei einer Assertion signiert ein Authenticator eine durch die Relying-Party vorgegebenen Challenge mithilfe eines FIDO-Credentials (private key). Dieser Vorgang kommt typischerweise bei Login-Operationen oder zur Bestätigung besonders sensibler Transaktionen zum Einsatz.
Attestation ¹	Als Attestation wird ein Mechanismus bezeichnet, mit dem ein Authenticator spezifische Informationen (insbesondere seine AAGUID) über sich selbst der Relying Party gegenüber nachweisen kann. Das geschieht dadurch, dass der Authenticator diese Informationen signiert und der Relying Party auf Anfrage bereitstellt. Je nach Konfiguration des Authenticators erfolgt diese Signatur durch selbsterstelltes Schlüsselmateriel oder durch bei der Fertigung eingebrachtes Schlüsselmateriel des Herstellers, dessen öffentlicher Teil beim FIDO Alliance Metadata-Service abgerufen werden kann. Die WebAuthn-Spezifikation sieht dabei die folgenden Attestierungsvarianten vor, die der Authenticator wählen kann: • Basic Attestation: Jeweils eine Modellserie von Authenticators besitzen einen identischen Attestation Key, der von einer vertrauenswürdigen CA signiert ist und der vom Hersteller bei Auslieferung auf dem Authenticator abgelegt wird. • Self Attestation: Der Authenticator besitzt keinen dedizierten Attestation Key. Stattdessen wird ein selbsterstelltes Schlüsselpaar für die Signatur des Attestation Statements verwendet. Dies bietet einen Integritätsschutz für die Bescheinigung und keine weiteren Garantien. • Attestation CA: Der Authenticator kann ein selbst erstelltes Schlüsselpaar von einer vertrauenswürdigen Attestation CA signieren lassen. Dazu ist die Verwendung eines Trusted Platform Module (TPM) notwendig, um eine vertrauenswürdige Kommunikation mit der CA zu gewährleisten. • Anonymization CA: Wie Attestation CA, außer dass für jedes Credential ein eigenes Attestation-Zertifikat signiert wird. Die Relying Party kann nur anhand des übertragenen Attestation Statements nicht unterscheiden, welche Variante vom Authenticator gewählt wurde. Die Relying Party kann darüber hinaus auch Präferenzen dazu kommunizieren, wie das Attestation Statement vom Authenticator übertragen werden soll: • none: Der Authenticator soll keine Attestierungsinformationen bereitstellen, • indirect: Der Authenticator soll Attestierungsinformationen bereitstellen, diese können jedoch vom FIDO-Client modifiziert werden (bspw. anonymisiert), • direct: Die Attestierungsinformationen des Authenticators sollen direkt weitergeleitet werden, • enterprise: Wie „direct“, außer, dass die Attestierungsinformationen zusätzlich noch identifizierende Informationen enthalten dürfen.

¹ [FIDO Attestation](#)

Begriff	Definition
Authenticator	Ein Authenticator ist eine kryptografische Einheit in Form von Hardware oder Software, die einen Benutzer bei einer bestimmten Relying Party registrieren und später den Besitz des registrierten öffentlichen Schlüssels bestätigen kann. • Plattform Authenticator: Bei einem Plattform Authenticator ist Schlüsselmaterial des FIDO-Authenticators an ein bestimmtes Benutzergerät (User Device) gebunden, das selbst für die FIDO-Authentisierung genutzt wird. • Roaming Authenticator: Bei einem Roaming Authenticator ist das Schlüsselmaterial des FIDO-Authenticators auf einem leicht transportierbaren Hardware-Gerät (i.d.R. ein Hardware-Token) gespeichert.
CTAP	Das Client To Authenticator Protocol (CTAP) beschreibt die Kommunikation zwischen Browsern oder Plattformen und FIDO-Authenticatoren.
FIDO Credential	Ein FIDO Credential ist ein asymmetrisches Schlüsselpaar, bestehend aus einem privaten Schlüssel, der auf dem Authenticator abgelegt wird, und einem öffentlichen Schlüssel, der während des Registrierungs Vorgangs an die Relying Party übertragen wird.
Meta Data Statement	Im sogenannten Meta Data Statement verwaltet die FIDO Alliance Informationen über Authenticators, die den FIDO-Zertifizierungsprozess durchlaufen haben. Bereitgestellt werden dort beispielsweise Informationen über das Zertifizierungslevel eines Authenticators, oder dessen Features. Das Meta Data Statement wird über den Meta Data Service bereitgestellt, der von der FIDO Alliance betrieben wird.
Passkey	Passkeys sind kryptografische FIDO-Anmeldeinformationen (FIDO-Credentials), die mit dem Benutzerkonto auf einer Website oder in einer Anwendung verknüpft sind. • Device Bound Passkeys sind FIDO-Credentials, die an eine bestimmte Hardware gebunden sind. • Synced Passkeys sind FIDO-Credentials, die zwischen unterschiedlichen Geräten synchronisiert werden können.
Relying Party	Die Entität, deren Webanwendung die Web Authentication API (WebAuthn) zur Registrierung und Authentifizierung von Benutzern verwendet.
Registration Ceremony	Beschreibt den Vorgang, bei dem FIDO2-Authentisierungsinformationen bei der Relying Party registriert werden. Dabei wird insbesondere ein öffentlicher Schlüssel bei der Relying Party hinterlegt, mit dem bei späteren Authentisierungsvorgängen Signaturen des Authenticators geprüft werden können.
Transaction	Eine Transaction im Kontext von Webanwendungen stellt eine sensitive Operation dar, welche unter der Kennung eines aktiven Benutzeraccounts eine privilegierte Zustandsänderung hervorruft. Zu der Transaction gehören entsprechende Transaktionsdaten, welche die durchzuführende Transaction parametrisieren bzw. beschreiben. Die Authentizität dieser Daten ist normalerweise von besonderem Interesse für den Benutzer und den Betreibenden der Webanwendung. Beispiele für Transactions in typischen Webanwendungen sind das Ändern von Account-Credentials, das Senden von Formulardaten zur Aufgabe von Bestellungen oder die Einsichtnahme besonders schützenswerter Accountdaten.

Begriff	Definition
User Presence	User Presence bzw. User Presence Check bezeichnet den Vorgang, bei dem ein Authenticator während der Erstellung bzw. der Verwendung eines FIDO-Credentials sicherstellt, dass eine Person physisch anwesend ist, die bestätigt, dass eine Operation ausgeführt werden soll. Dies kann beispielsweise durch Drücken eines Knopfes am Authenticator überprüft werden.
User Verification	Hierbei überprüft der Authenticator, ob die Benutzer berechtigt sind, das Schlüsselmateriale zu verwenden. Dies kann beispielsweise durch Abgleich eines Fingerabdrucks oder einer PIN sichergestellt werden.

Tabelle 2: Wichtige Definitionen und Begrifflichkeiten

2.2 Berücksichtigte Versionen von Spezifikationen und Richtlinien

Sofern nicht explizit anders angegeben, beziehen sich alle Inhalte des folgenden Dokuments immer auf die folgenden Versionen der jeweiligen Standards und Richtlinien.

Spezifikation	Version	Referenz
Web Authentication: An API for accessing Public Key Credentials (WebAuthn)	Level 2, Version vom 08.04.2021	https://www.w3.org/TR/webauthn-2
FIDO Authenticator Security Requirements	Version vom 20.12.2023	https://fidoalliance.org/specs/fido-security-requirements-v1.0-fd-20170524/fido-authenticator-security-requirements_20170524.html
FIDO Security Reference	Version vom 23.05.2022	https://fidoalliance.org/specs/common-specs/fido-security-ref-v2.1-ps-20220523.html
IANA WebAuthn Extensions Registry	Version vom 13.09.2023	https://www.iana.org/assignments/webauthn/webauthn.xhtml
TR-03107-1: Elektronische Identitäten und Vertrauensdienste im E-Government Teil 1	Version vom 07.05.2019	https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03107/TR-03107-1.html
FIDO Authenticator Allowed Cryptography List	Version vom 20.12.2023	https://fidoalliance.org/specs/fido-security-requirements-v1.0-fd-20170524/fido-authenticator-allowed-cryptography-list_20170524.html

Tabelle 3: Übersicht über die berücksichtigten Standards mitsamt Version

3 Sicherheitsempfehlung

In diesem Abschnitt werden unterschiedliche Konfigurationen von Passkey Servern (FIDO2 Server) systematisch erfasst und beschrieben. Die sich daraus ergebende **Sicherheitsempfehlung** enthält konkrete Maßnahmen, die umgesetzt werden müssen, um ein bestimmtes Vertrauensniveau zu erreichen. Zuvor werden die notwendigen Rahmenbedingungen für diese Maßnahmen näher dargelegt und eingeordnet.

3.1 FIDO Security Reference

In einem Angreifermodell werden sicherheitsrelevante Annahmen und Anforderungen an ein betrachtetes Protokoll, an involvierte Protokollparteien und auch an den Angreifer festgelegt. Insbesondere enthält ein Angreifermodell Informationen dazu, welche Protokollparteien zu welchem Grad als vertrauenswürdig gelten. Hierzu zählt beispielsweise, dass alle involvierten Parteien vollständig vertrauenswürdig sind. Es enthält weiterhin Informationen dazu, welche Fähigkeiten Angreifenden zugestanden werden, z. B. das Verschicken von manipulierten Links, nicht aber der Eingriff in Netzwirkkommunikation. Die Festlegung auf ein Angreifermodell ist die Grundlage für jede Sicherheitsbetrachtung. Insbesondere kann die Wirksamkeit von Sicherheitsmaßnahmen nur immer in Hinblick auf ein konkretes Angreifermodell bewertet werden. Threats oder Bedrohungen sind konkrete Angriffe, die innerhalb eines festen Angreifermodells realisiert werden können, bspw. das Durchführen von Real-Time-Phishing-Angriffen. Sicherheitsziele oder Security Goals beschreiben, welche Informationen oder Güter vor einem Angriff geschützt werden sollen und welche Eigenschaften eines Protokolls immun durch Angriffe sein sollen. Sicherheitsziele sind häufig allgemeingültig und unabhängig von einem Angreifermodell definiert. Die Frage, ob ein Sicherheitsziel erfüllt werden kann oder nicht, kann aber immer nur im Kontext eines definierten Angreifermodells und unter Berücksichtigung der angewendeten Sicherheitsmechanismen beantwortet werden.

Das aktuell durch den FIDO2-Standard betrachtete Angreifermodell geht aus den in der FIDO Security Reference beschriebenen Protokollparteien sowie sicherheitsrelevanten Annahmen hervor und wird unter Angreifermodell 0 (AM-0) näher beschrieben.

3.1.1 Protokollparteien

Das in der FIDO Security Reference abgebildete Modell kennt die folgenden relevanten Protokollparteien:

Relying Party (Server): diejenige Partei, gegenüber der eine FIDO-Authentisierung erfolgen soll

User Device: das Gerät, das zur Durchführung einer FIDO-Authentisierung genutzt wird, z. B. Laptop

Relying Party App: die Softwarekomponente auf dem User Device, die für die FIDO-Authentisierung genutzt wird

FIDO Client / Browser: diejenige Komponente, die auf Seite des Benutzers mit der Relying Party App interagiert und für den Authenticator CTAP-Nachrichten erstellt bzw. verarbeitet

Authenticator: die Software- oder Hardwarekomponente, die das zur FIDO-Authentisierung verwendete Schlüsselmaterial hält und Signaturen erstellen kann

Grundsätzlich soll durch eine FIDO-Authentisierung eine Vertrauensbeziehung zwischen einem Benutzer und der Relying Party über einen nicht oder wenig vertrauenswürdigen Kanal (z.B. das Internet) hergestellt werden, sodass der Benutzer Zugriff auf für ihn vorgehaltene Informationen erhalten kann. Auch wenn der User in der FIDO Security Reference nicht gesondert modelliert ist, sollte er daher als zusätzliche Protokollpartei betrachtet werden.

3.1.2 Sicherheitsrelevante Annahmen

Die FIDO Security Reference postuliert eine Reihe von sicherheitsrelevanten Annahmen (Security Assumptions oder SA), die für eine sichere Protokolldurchführung und insbesondere für die Realisierung der Security Goals (SG) notwendig sind:

[SA-1] Der Authenticator und seine verwendeten kryptografischen Algorithmen und Parameter (Schlüsselgröße, Modus, Ausgabelänge usw.) weisen keine unbekannten Schwachstellen auf, die ihn für seinen Zweck zum Verschlüsseln, digitalen Signieren und Authentifizieren von Nachrichten ungeeignet machen.

[SA-2] Die Mechanismen der Privilegientrennung des Betriebssystems, auf die sich die an einem FIDO-Vorgang auf dem Benutzergerät beteiligten Softwaremodule verlassen, funktionieren wie angekündigt. So werden z. B. die Grenzen zwischen Benutzer- und Kernelmodus, zwischen Benutzerkonten und zwischen Anwendungen (sofern zutreffend) sicher durchgesetzt, und die Sicherheitsprinzipale können gegenseitig sicher identifiziert werden.

[SA-3] Anwendungen auf dem Benutzergerät sind in der Lage, sichere Kanäle einzurichten, die eine vertrauenswürdige Serverauthentifizierung sowie die Vertraulichkeit und Integrität von Nachrichten gewährleisten (z. B. durch TLS).

[SA-4] Die Computerumgebung auf dem FIDO-Benutzergerät und die an einem FIDO-Vorgang beteiligten Anwendungen fungieren als vertrauenswürdige Agenten des Benutzers.

[SA-5] Der inhärente Wert eines kryptografischen Schlüssels liegt in dem Vertrauen, das er vermittelt, und dieser Wert nimmt mit der Zeit ab, unabhängig von einem Kompromittierungsereignis. Infolgedessen wird das effektive Sicherheitsniveau von Authenticatoren mit der Zeit abnehmen.

[SA-6] Die an der Verarbeitung einer FIDO-Operation beteiligten Rechenressourcen bei der Relying Party fungieren als vertrauenswürdige Agenten der Relying Party.

3.1.3 Sicherheitsziele

Die FIDO Security Reference beschreibt 16 Sicherheitsziele (Security Goals), die beim Entwurf des FIDO-Authentisierungsverfahrens berücksichtigt wurden.

ID	Sicherheitsziel	Beschreibung
SG-1	Strong User Authentication	Benutzer oder Geräte sollen von der Relying Party mit hoher Konfidenz authentifiziert werden können.
SG-2	Credential Guessing Resilience	Das Protokoll soll resistent dagegen sein, dass Credentials erraten werden können.
SG-3	Credential Disclosure Resilience	Das Protokoll soll resistent gegen (Real-Time-)Phishing-Angriffe sein.
SG-4	Unlinkability	Zwei Relying Parties dürfen anhand von Protokollnachrichten nicht ermitteln können, ob es sich um den gleichen Benutzer handelt.
SG-5	Verifier Leak Resilience	Keine Daten, die eine Relying Party über einen Benutzer leaken kann, dürfen einem Angreifer dabei helfen, diesen Benutzer zu imitieren.

ID	Sicherheitsziel	Beschreibung
SG-6	Authenticator Leak Resilience	Daten, die von einem speziellen Authenticator leaked werden, können nicht dazu verwendet werden, Angriffe auf andere Benutzer durchzuführen.
SG-7	User Consent	Benutzer müssen darüber informiert werden, wenn eine Registrierung bei einer neuen Relying Party erfolgen soll.
SG-8	Limited PII	Die Menge an personenbezogenen Daten, die der Relying Party bekannt gegeben wird, soll minimal sein.
SG-9	Attestable Properties	Die Relying Party muss in der Lage sein, Art und Modell des verwendeten Authenticators zu überprüfen.
SG-10	DoS Resistance	Angreifer dürfen nicht in der Lage sein, Benutzeraccounts durch das Einfügen von ungültigen Registrierungsinformationen in eine Protokollnachricht unbrauchbar zu machen.
SG-11	Forgery Resistance	Kommunikation, die von einem Angreifer abgefangen wurde, kann nicht derart modifiziert werden, dass sie sich dafür eignet, sich im Namen des Benutzers zu authentifizieren.
SG-12	Parallel Session Resistance	Kommunikation, die von einem Angreifer abgefangen wurde, kann nicht dazu verwendet werden, neue und zugleich gültige Authentisierungsinformationen zu erhalten.
SG-13	Forwarding Resistance	Das Protokoll ist resistent gegenüber Replay- und Forwarding-Angriffen.
SG-14	Transaction Non-Repudiation	Das Protokoll bietet ein hohes Maß an Nichtabstreitbarkeit.
SG-15	Respect for Operating Environment Security Boundaries	Vertrauliche Informationen, wie privates Schlüsselmaterial, sollen entsprechend den Sicherheitsgrenzen der Betriebsumgebung geschützt werden.
SG-16	Assessable Level of Security	Das Sicherheitslevel von Authenticators soll durch einen Zertifizierungsprozess überprüfbar sein.

Tabelle 4: Übersicht über die in der FIDO Security Reference definierten Sicherheitsziele

3.1.4 Bedrohungen

Die FIDO Security Reference enthält zum aktuellen Zeitpunkt 66 verschiedene Sicherheitsbedrohungen (Threats), die beim Entwurf des FIDO-Protokolls berücksichtigt wurden. In der Security Reference wird diskutiert, ob und wenn ja, wie diese Bedrohungen jeweils durch Sicherheitsmechanismen oder sicherheitsrelevante Annahmen neutralisiert werden. Im Folgenden werden diejenigen Bedrohungen, die für eine Relying Party und somit auch für die Webseitenbetreibenden relevant sind, vorgestellt und jeweils vermerkt, inwiefern diese Bedrohungen – nach Darstellung der FIDO Security Reference – durch in der WebAuthn-Spezifikation veranlagte Sicherheitsmechanismen bereits adressiert werden.

Dabei muss berücksichtigt werden, dass in der aktuell verfügbaren Version der FIDO Security Reference auch Sicherheitsmechanismen (bspw. Transaction Authentication und Token Binding) referenziert werden, die in der aktuellen Entwurfsversion der WebAuthn-Spezifikation nicht mehr vorhanden sind und damit in der Praxis zukünftig nicht mehr nutzbar sein werden.

ID	Name	Beschreibung	Durch WebAuthn adressiert?
T-1.1.1	Homograph Mis-Registration	Ein Benutzer registriert seine Credentials bei der falschen Relying Party, bspw. weil er durch einen ähnlich aussehenden Domain-Namen dazu verleitet wurde.	Nein
T-1.1.2	Homograph Mis-Authentication	Ein Benutzer versucht, eine FIDO-Authentisierung gegenüber einer falschen Relying Party durchzuführen, bspw. weil er durch einen ähnlich aussehenden Domain-Namen dazu verleitet wurde.	Ja
T-1.2.4	App Server Verification Error	Die Client-Applikation verifiziert die Identität der Relying Party nicht korrekt, sodass ein Angreifer die Verbindung als „Man in the Middle“ angreifen kann.	Ja (basiert u.a. auf Token Binding, das aktuell nicht nutzbar ist)
T-1.2.5	RP App Corruption	Der Angreifer kann Code im Kontext der Relying Party App ausführen, bspw. durch einen XSS-Angriff.	Ja (basiert u.a. auf Transaction Authentication, das aktuell nicht nutzbar ist)
T-1.2.11	Malicious FIDO Client	Der Angreifer überzeugt die Benutzer, einen böartigen FIDO-Client zu installieren und zu verwenden.	Ja (basiert u.a. auf Transaction Authentication, das aktuell nicht nutzbar ist)
T-1.4.1	Malicious Authenticator	Der Angreifer bringt den Benutzer dazu, einen manipulierten Authenticator zu nutzen.	Ja
T-1.4.3	User Verification By-Pass	Der Angreifer benutzt die im Authenticator gespeicherten Credentials, ohne dass eine Benutzerverifikation erfolgt.	Ja
T-2.1.1	FIDO Server DB Read Attack	Ein Angreifer erhält lesenden Zugriff auf die FIDO-Datenbank der Relying Party.	Nein
T-2.1.2	FIDO Server DB Modification Attack	Ein Angreifer erhält schreibenden Zugriff auf die FIDO-Datenbank der Relying Party.	Nein
T-2.2.1	Web App Malware	Ein Angreifer kann Code im Kontext der Relying Party App oder des FIDO-Servers ausführen.	Ja (basiert u.a. auf Transaction Authentication, das aktuell nicht nutzbar ist)
T-2.2.2	Linking through compromised Relying Party database	Ein Angreifer nutzt Informationen aus der FIDO-Datenbank einer anderen Relying Party, um zu versuchen, den verwendeten Authenticator zu identifizieren.	Ja
T-2.3.1	Re-used Server Nonce	Die Relying Party verwendet eine Nonce wieder.	Nein
T-2.3.2	Predictable Server Nonce	Die Relying Party verwendet berechenbare Nonces.	Nein

ID	Name	Beschreibung	Durch WebAuthn adressiert?
T-3.1.1	TLS Proxy	Der Client kommuniziert mit der Relying Party über einen TLS-Proxy, der TLS-Verbindungen terminiert.	Ja (basiert u.a. auf Token Binding, das aktuell nicht nutzbar ist)
T-3.1.2	Fraudulent TLS Server Certificate	Ein Angreifer kommt in Besitz eines gültigen TLS-Zertifikats für die Domain der Relying Party.	Ja
T-3.1.3	Protocol level real-time MITM attack	Der Angreifer führt einen real-time MitM-Angriff durch, in dem er die TLS-Verbindung des FIDO-Clients beendet und selbst eine TLS-Verbindung zu der Relying Party aufbaut.	Ja (basiert u.a. auf Token Binding oder Transaction Authentication, die aktuell nicht nutzbar sind)
T-4.2.1	Vendor Level Trust Anchor Injection Attack	Ein Angreifer fügt der vom FIDO-Serveranbieter mitgelieferten Vertrauensliste bösartige Vertrauensanker hinzu.	Nein

Tabelle 5: Übersicht über diejenigen Bedrohungen aus der FIDO Security Reference, die die Relying Party betreffen

3.2 Angreifermodelle

Im Folgenden werden die Angreifermodelle vorgestellt, auf deren Grundlage die Auswahl der Sicherheitsmechanismen für die drei Vertrauensniveaus erfolgt ist. Dabei bildet das Angreifermodell 0 (AM-0) die Basis für die weiteren Angreifermodelle und geht aus der FIDO Security Reference hervor. Sofern die darauf aufbauenden Angreifermodelle ein neues Sicherheitsziel oder eine neue Bedrohung implizieren, werden diese nachfolgend ebenfalls dargestellt. Dabei wird die Nummerierung der Sicherheitsziele aus der FIDO Security Reference nach SG-16 weitergeführt. Für die Bedrohungen wurde eine neue Ordnungsnummer „T-6.1.X“ eingeführt, die anschließend aufsteigend nummeriert weitergeführt wird.

3.2.1 Angreifermodell 0 (AM-0)

Aus den sicherheitsrelevanten Annahmen SA-2 und SA-4 geht unmittelbar hervor, dass dem User Device und der Relying Party App nahezu uneingeschränkt vertraut werden muss. Einzige Einschränkung davon ist der Fall, in dem eine nicht vertrauenswürdige Software mit Benutzerrechten ausgeführt wird – in diesem Fall schützt jedoch die durch das Betriebssystem garantierte Privilege Separation.

Aus sicherheitsrelevanten Annahme SA-3 geht hervor, dass die Identität der Relying Party durch alle Applikationen, die auf dem User Device laufen, zweifelsfrei validiert werden kann. SA-6 postuliert die uneingeschränkte Vertrauenswürdigkeit der Relying Party.

Zusammenfassend lässt sich feststellen, dass alle Protokollparteien per Security Assumption als vertrauenswürdig definiert werden und das Tätigkeitsfeld des Angreifers auf Angriffe auf und über den Übertragungsweg (bspw. das Internet) beschränkt wird.

Abbildung 1 zeigt das resultierende Angreifermodell schematisch.

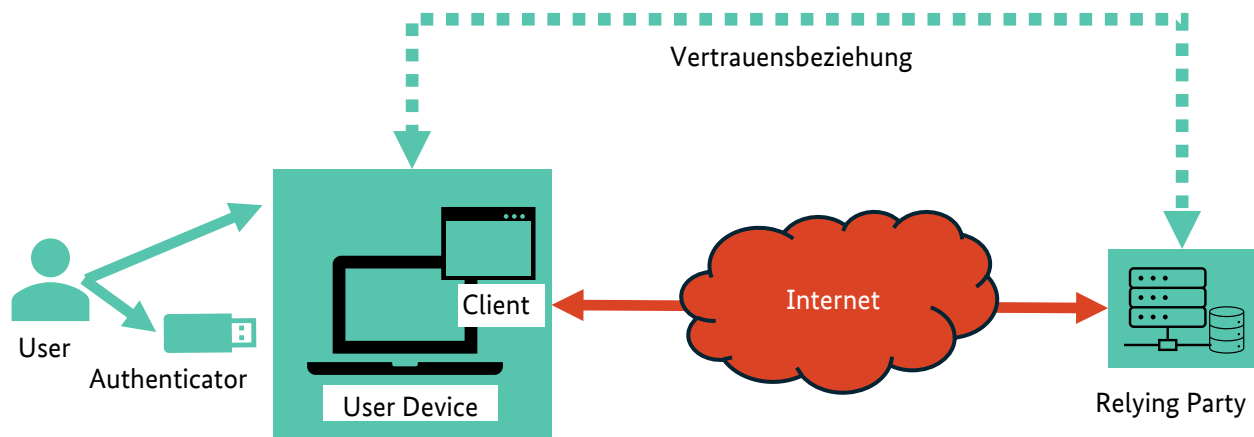


Abbildung 1: FIDO-Angreifermodell. Alle involvierten Parteien sind vollständig vertrauenswürdig. Einzig der Übertragungsweg der ausgetauschten Informationen (Internet) ist nicht vertrauenswürdig.

Obwohl die Gewährleistung einer sicheren Authentisierung selbst in diesem eingeschränkten Angreifermodell schon eine besondere Leistung ist, gibt es in der Praxis noch einige weitere mögliche Angriffsszenarien.

3.2.2 Angreifermodell 1 (AM-1)

Ein Angreifermodell, welches bisher keine explizite Berücksichtigung in der FIDO Security Reference findet, ist, dass ein Angreifer seine physische Nähe zu einem fremden Authenticator ausnutzt, um einen FIDO-Authentisierungsvorgang durchzuführen. Das kann beispielsweise dann möglich sein, wenn der Authenticator eine NFC-Schnittstelle besitzt, über die ein Angreifer gültige Assertions erhalten kann.

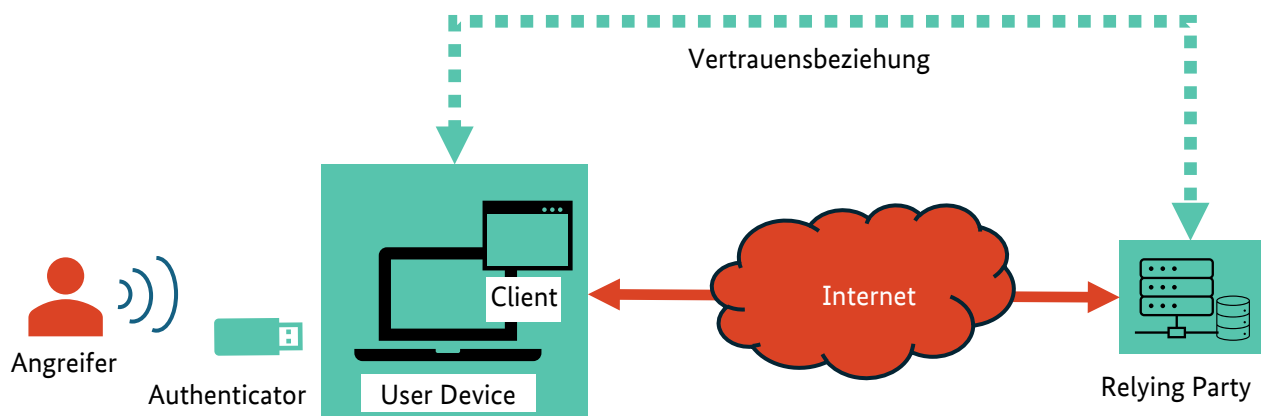


Abbildung 2: Schematische Darstellung des Angreifermodells 1. Ein Angreifer kann die physische Nähe zu einem Authenticator ausnutzen, um einen Authentisierungsvorgang auszulösen.

Daraus ergibt sich das folgende zusätzliche Sicherheitsziel, das bisher nicht durch die FIDO Security Reference adressiert wird:

ID	Sicherheitsziel	Beschreibung
SG-17	Assertion Consent	Es muss sichergestellt sein, dass ein Authenticator keine Assertion ohne Zustimmung des Nutzenden ausstellt.

Tabelle 6: Übersicht über das neue Sicherheitsziel in AM-1.

Ergänzend dazu ergibt sich die folgende neue Bedrohung:

ID	Threat	Beschreibung
T-6.1.1	User Consent Bypass	Der Angreifer nutzt physischen Zugriff auf den Authenticator, um unbemerkt eine Assertion auszustellen.

Tabelle 7: Übersicht über die neue Bedrohung in AM-1.

3.2.3 Angreifermodell 2 (AM-2)

Ein weiteres relevantes Angreifermodell ist, dass der User selbst nicht vertrauenswürdig ist. Dieses Angreifermodell deckt insbesondere den Fall ab, dass der Nutzer eines Authenticators nicht auch dessen Eigentümer ist – beispielsweise, weil der Authenticator gestohlen wurde. Ein Angreifer kann einen gestohlenen Authenticator dazu verwenden, einen FIDO-Authentisierungsvorgang durchzuführen.

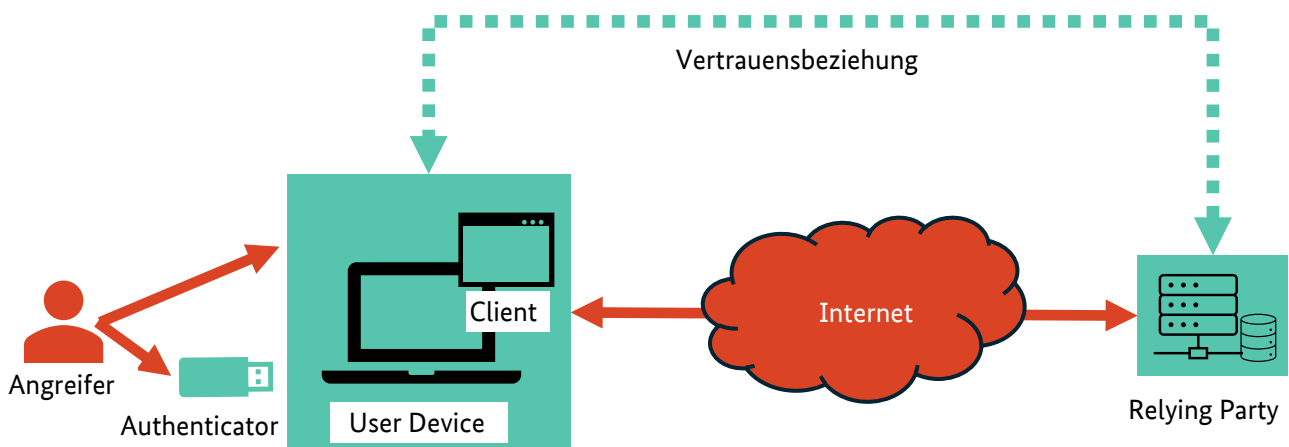


Abbildung 3: Schematische Darstellung des Angreifermodells 2. In diesem Modell ist der User selbst nicht vertrauenswürdig, beispielsweise, weil es sich um einen Angreifer handelt, der einen gestohlenen Authenticator verwendet.

Daraus ergibt sich das folgende zusätzliche Sicherheitsziel, das bisher nicht durch die FIDO Security Reference adressiert wird:

ID	Sicherheitsziel	Beschreibung
SG-18	Strong User Verification	In Erweiterung zu SG-1 muss sichergestellt sein, dass der Authenticator vor Ausstellung einer Assertion den Nutzenden verifiziert.

Tabelle 8: Übersicht über das neue Sicherheitsziel in AM-2.

3.2.4 Angreifermodell 3 (AM-3)

In diesem Angreifermodell hat die Relying Party einen Account-Wiederherstellungsprozess mit einem geringeren Vertrauensniveau, als durch eine FIDO-Authentisierung gewährleistet wird. Ein Angreifer kann diesen Prozess ausnutzen, um die FIDO-Authentisierung zu umgehen.

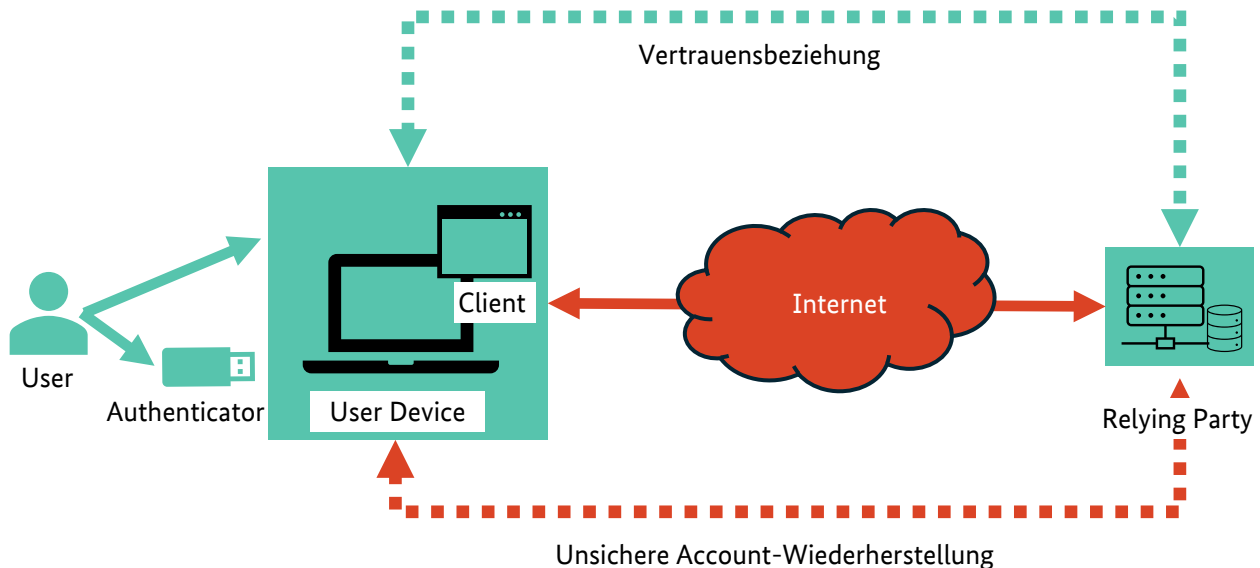


Abbildung 4: Schematische Darstellung des Angreifermodells 3. Die Relying Party bietet einen Account-Wiederherstellungsprozess an, der ein geringeres Vertrauensniveau hat, als die FIDO-Authentisierung.

Daraus ergibt sich das folgende zusätzliche Sicherheitsziel, das bisher nicht durch die FIDO Security Reference adressiert wird:

ID	Sicherheitsziel	Beschreibung
SG-19	Strong Account Recovery	Der Account-Wiederherstellungsprozess soll auf dem gleichen oder einem höheren Vertrauensniveau wie die FIDO-Authentisierung stattfinden.

Tabelle 9: Übersicht über das neue Sicherheitsziel in AM-3.

Ergänzend dazu ergibt sich die folgende neue Bedrohung:

ID	Threat	Beschreibung
T-6.1.2	Account Recovery Abuse	Der Angreifer nutzt einen schwächeren Mechanismus zur Account-Wiederherstellung, um die Notwendigkeit einer FIDO-Authentisierung zu umgehen.

Tabelle 10: Übersicht über die neue Bedrohung in AM-3.

3.2.5 Angreifermodell 4 (AM-4)

Dieses Angreifermodell bildet den Fall ab, dass das User Device oder der darauf befindliche Client kompromittiert ist. In diesem Fall kann ein Angreifer unter anderem FIDO-Assertions für beliebige Dienste ausstellen oder den Benutzer dazu bringen, ungewollte Interaktionen mit einer Webseite auszulösen.

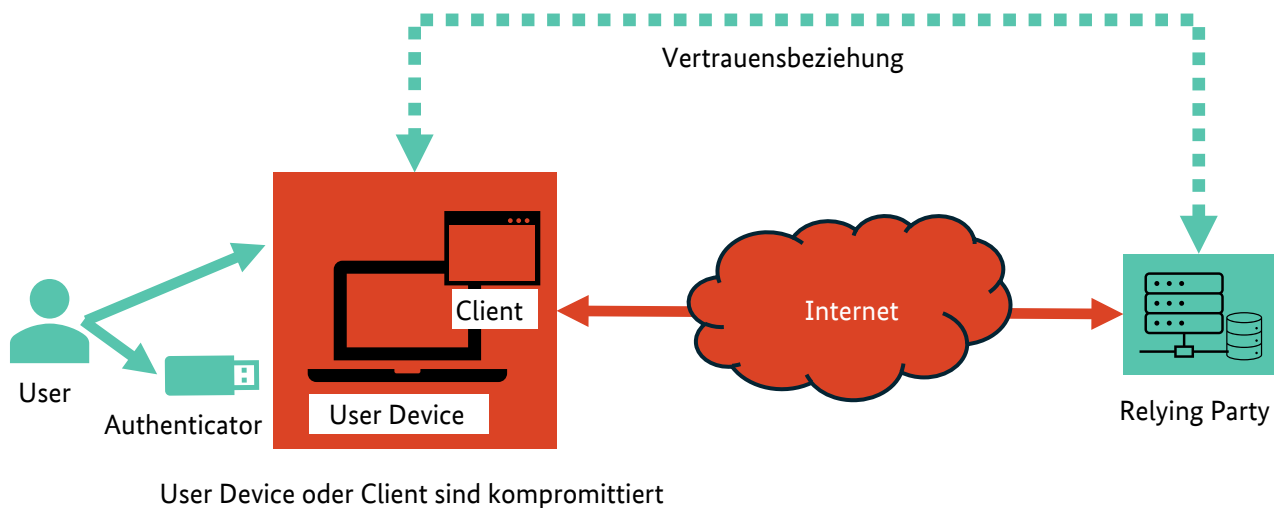


Abbildung 5: Schematische Darstellung des Angreifermodells 4. Das User Device oder der Client sind kompromittiert.

Daraus ergibt sich das folgende zusätzliche Sicherheitsziel, das bisher nicht durch die FIDO Security Reference adressiert wird:

ID	Sicherheitsziel	Beschreibung
SG-20	Transaction Authentication	Das Protokoll soll Benutzern die Möglichkeit bieten, einzelne Transaktionen zu autorisieren, indem die Relying Party eine Eingabeaufforderung auf dem Authenticator anzeigen lässt.

Tabelle 11: Übersicht über das neue Sicherheitsziel in AM-4.

Ergänzend dazu ergibt sich die folgende neue Bedrohung:

ID	Threat	Beschreibung
T-6.1.3	Session Hijacking	Der Angreifer erlangt Session-Informationen aus einer bereits authentifizierten Benutzer-Session und verwendet diese, um im Namen des Benutzers mit der Webseite zu interagieren. Das kann beispielsweise über einen kompromittierten FIDO-Client erfolgen (T-1.2.11), aber auch über verschiedene andere Wege.

Tabelle 12: Übersicht über die neue Bedrohung in AM-4.

Ein wirksamer Mechanismus, um derartigen Angriffen zu begegnen, ist die sogenannte Transaction Authentication, bei der weitere Informationen zu der jeweiligen Interaktion mit der Relying Party an den Authenticator übertragen werden. Transaction Authentication ist in der aktuellen Version der WebAuthn-Spezifikation noch enthalten, wird jedoch aller Voraussicht nach in der nächsten Version herausgenommen². Transaction Authentication ist darüber hinaus auch in keinem aktuellen Browser mehr implementiert.

² <https://www.w3.org/TR/webauthn-3/>

3.2.6 Angreifermodell 5 (AM-5)

In diesem Angreifermodell wird der private Schlüssel des von der Relying Party verwendeten TLS-Zertifikats offengelegt, die Relying Party wurde jedoch nicht vollständig kompromittiert. Der Angreifer kann diesen Schlüssel nun nutzen, um einen MitM-Angriff auf eine bereits bestehende Verbindung zwischen Client und Relying Party durchzuführen. Außerdem muss der Angreifer die Kommunikation aktiv manipulieren, um das User Device oder den Client auf eine manipulierte Webseite umzuleiten.

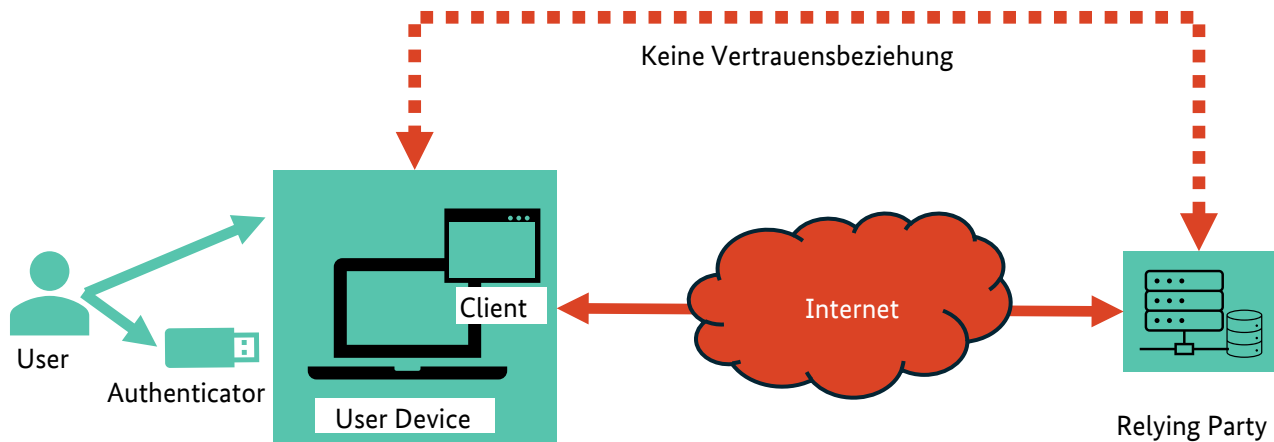


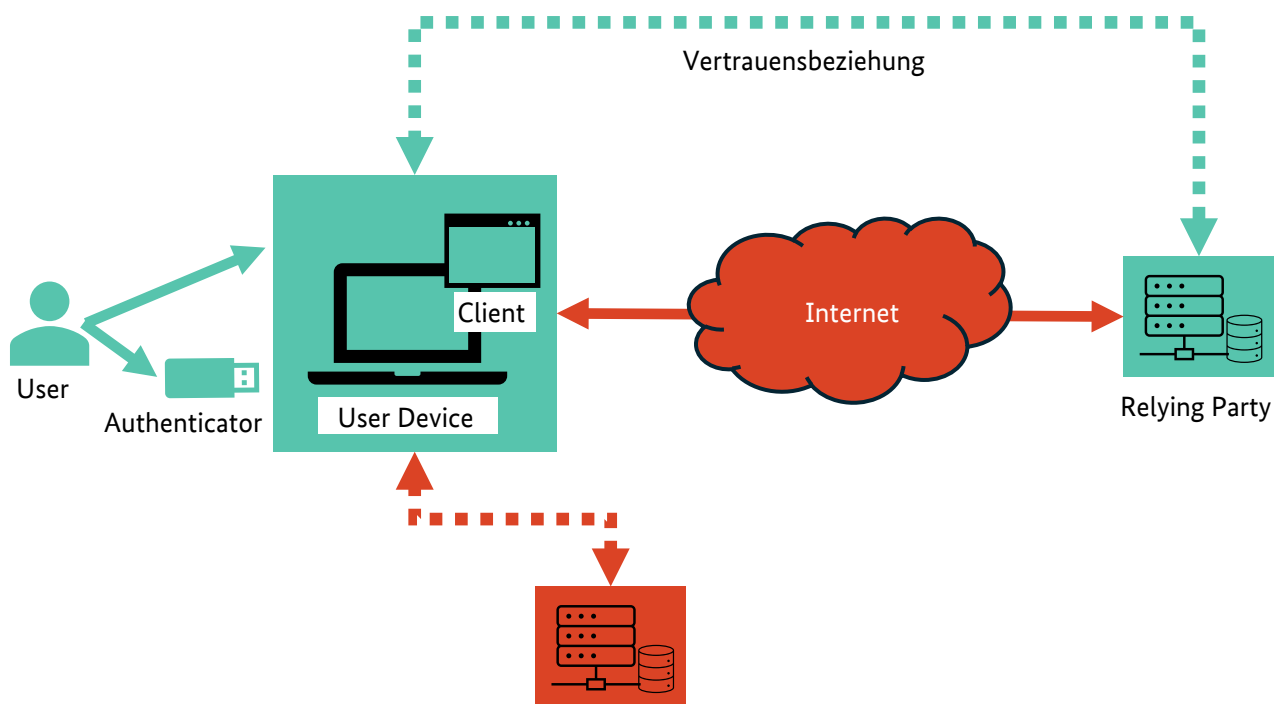
Abbildung 6: Schematische Darstellung des Angreifermodells 5. Zwischen dem User Device bzw. Client und der Relying Party kann keine Vertrauensbeziehung hergestellt werden.

Ein wirksamer Mechanismus, mit dem derartige Angriffe zumindest in einigen Fällen erkannt werden könnten, ist das sogenannte Token Binding, bei dem ein Authentisierungstoken an eine bestehende TLS-Sitzung gekoppelt wird. Token Binding ist in der aktuellen Version der WebAuthn-Spezifikation noch enthalten, wird jedoch aller Voraussicht nach in der nächsten Version herausgenommen³.

3.2.7 Angreifermodell 6 (AM-6)

In diesem Angreifermodell werden auf dem Authenticator gespeicherte FIDO-Credentials zu einem nicht vertrauenswürdigen Cloud-Dienst synchronisiert oder über einen unsicheren Kanal übertragen. Das kann beispielsweise dann der Fall sein, wenn Synced Passkeys verwendet werden.

³ <https://www.w3.org/TR/webauthn-3/>



Synchronisation der Credentials zu einem unsicheren Cloud-Service

Abbildung 7: Schematische Darstellung des Angreifermodells 6. Das FIDO-Credential wird zu einem unsicheren Cloud-Service synchronisiert.

Daraus ergibt sich das folgende zusätzliche Sicherheitsziel, das bisher nicht durch die FIDO Security Reference adressiert wird:

ID	Sicherheitsziel	Beschreibung
SG-21	Strong Authenticator Assurance	Es muss ausreichend sichergestellt werden, dass nur Device Bound Passkeys verwendet werden und der Authenticator somit keine Synchronisation der FIDO-Credentials zulässt.

Tabelle 13: Übersicht über das neue Sicherheitsziel in AM-6.

Ergänzend dazu ergibt sich die folgende neue Bedrohung:

ID	Threat	Beschreibung
T-6.1.4	Synchronised Credential Leak	Ein FIDO-Credential wird mit der Cloud synchronisiert und ein Angreifer erhält Zugriff auf das Credential.

Tabelle 14: Übersicht über die neue Bedrohung in AM-6.

3.3 Vertrauensniveaus

Auf Grundlage der bereits existierenden technischen Richtlinien arbeitet dieses Dokument die Möglichkeiten der FIDO2-Protokollfamilie auf, Authentisierungsvorgänge gemäß den Bedürfnissen der Anwender zu gestalten. Angelehnt an die TR-03107-1 (Elektronische Identitäten und Vertrauensdienste im E-Government Teil 1) werden im Weiteren die Vertrauensniveaus normal (NRM), substantiell (SBT) sowie hoch (HCH) verwendet. Für Anwendungen im E-Government kann es sein, dass über die in dieser TR genannten weitere Anforderungen aus der TR-03107 beachtet werden müssen. Weiterhin ist die Sicherheit eines Authentisierungssystems von weiteren Faktoren abhängig, die jedoch nicht von einer vertrauenden Stelle wie dem Passkey Server geprüft werden können und die deshalb nicht im Bereich dieser TR liegen. Die Feststellung des notwendigen Vertrauensniveaus erfolgt ebenfalls auf Grundlage der TR-03107-1.

Jedes Vertrauensniveau adressiert dabei eines oder mehrere der definierten Angreifermodelle, indem bestimmte Konfigurationsoptionen, Anforderungen, Verwendungsvarianten oder Erweiterungen der WebAuthn-Spezifikation als verbindlich vorgegeben werden.

Eine kurze Übersicht der drei Vertrauensniveaus liefert die folgende Tabelle. Dabei ist impliziert, dass alle Vertrauensniveaus derart gestaltet sind, dass sie die Sicherheit des FIDO-Verfahrens nicht abschwächen und somit die Sicherheit gegenüber Angreifermodell AM-0 auf allen drei Vertrauensniveaus bestehen bleibt. Jedes Vertrauensniveau adressiert dann ein oder mehrere zusätzliche Angreifermodelle im Vergleich zu dem vorangehenden Niveau.

Entsprechend der Vorgaben aus der TR-03107-1 genügt für das Vertrauensniveau „normal“ ein einzelner Authentisierungsfaktor (Besitz eines privaten Schlüssels), ohne wesentliche Einschränkungen an den Authenticator vorzunehmen. Dabei werden erste Maßnahmen ergriffen, um die Verwendung des privaten Schlüssels durch Unberechtigte zu verhindern. Vertrauensniveau „substantiell“ fordert dann 2FA und etabliert weitere Mechanismen. Vertrauensniveau „hoch“ schließlich erfordert den Einsatz eines Authenticators, bei dem das Schlüsselmaterial nachweislich durch Hardwareschutzmaßnahmen sicher gespeichert wird, sowie weitreichende Forderungen an die Absicherung von Kommunikationsbeziehungen.

Wie bereits erläutert, sind verschiedene Sicherheitsmechanismen, die in der aktuellen Version der WebAuthn-Spezifikation noch vorgesehen sind, in aktuellen Browsern nicht mehr implementiert und werden zukünftig voraussichtlich auch nicht mehr Teil von WebAuthn sein. Aus diesem Grund ist eine sichere Authentisierung in den Angreifermodellen **AM-4** und **AM-5** auf Basis von Sicherheitsmechanismen, die WebAuthn bereitstellt, nicht realisierbar.

Vertrauensniveau	Angreifermodelle	Zentrale Sicherheitsmechanismen
normal (NRM)	AM-0, AM-1	Prüfung der User Presence durch die Relying Party, um unbemerkte Authentisierungsvorgänge zu verhindern
substantiell (SBT)	AM-2, AM-3	Verwendung von User Verification, Sichere Account-Wiederherstellung
hoch (HCH)	AM-4, AM-5 , AM-6	Prüfung AAGUID und Attestation Statement, Transaction Authentication, Token Binding , ausschließlich Device Bound Passkeys sind zugelassen

Tabelle 15: Überblick über die drei Vertrauensniveaus. Angreifermodelle, die in roter Schrift dargestellt werden, sind aktuell und perspektivisch mit den im WebAuthn-Standard vorhandenen Sicherheitsmechanismen nicht adressierbar.

3.4 Sicherheitsmechanismen

Im Folgenden wird dargestellt, welche Sicherheitsmaßnahmen und Konfigurationsoptionen auf Seiten der Relying Party umgesetzt werden müssen, um ein bestimmtes Vertrauensniveau der Authentisierung gewährleisten zu können. Diese Maßnahmen werden gemäß RFC 2119⁴ mit den folgenden Schlüsselwörtern gekennzeichnet und wie folgt verwendet:

1. MUSS: Diese Anforderung muss unter allen Umständen erfüllt sein.
2. DARF NICHT: Der beschriebene Sachverhalt darf unter keinen Umständen erfüllt sein.
3. SOLLTE: Diese Anforderung muss erfüllt sein, sofern keine guten Gründe dem entgegenstehen.
4. SOLLTE NICHT: Der beschriebene Sachverhalt darf nicht erfüllt sein, es sei denn gute Gründe machen das erforderlich.

Für die Maßnahmen werden zusätzlich noch dargestellt, aus welcher Passage eines Spezifikationsdokumentes oder einer Richtlinie sie hervorgeht sowie welches Sicherheitsziel und welche Bedrohung dadurch adressiert werden. Dabei ist diese Zuordnung nicht immer vollständig für jede Maßnahme möglich, da beispielsweise einige Anforderungen grundlegend neu erstellt wurden und nicht direkt aus Konfigurationsoptionen hervorgehen, die die WebAuthn-Spezifikation bietet. Weiterhin wurden alle sicherheitsrelevanten MUST-, SHOULD- und MAY-Anforderungen aus der WebAuthn-Spezifikation den Vertrauensniveaus „normal“, „substantiell“ und „hoch“ eingeordnet, auch wenn diese Anforderungen nicht immer mit einem Sicherheitsziel oder Threat in Bezug stehen. Nicht erfüllbare Maßnahmen sind hingegen mit roter Farbe hinterlegt.

Darüber hinaus erhalten die Maßnahmen (sofern möglich) jeweils Bezug auf die Quelle der Anforderung (z.B. §1 WebAuthn) und der dort gewählten Kategorisierung:

MUST-Anforderung: Die aufgeführte Anforderung wird in der WebAuthn-Spezifikation als für die Relying Party verpflichtend aufgeführt.

SHOULD-Anforderung: Die WebAuthn-Spezifikation fordert, dass die Relying Party die aufgeführten Anforderungen umsetzen muss, sofern keine guten Gründe dagegenstehen.

MAY-Anforderung: Die WebAuthn-Spezifikation stellt der Relying Party frei, ob sie die aufgeführte Anforderung umsetzt oder nicht.

Parameter: Die WebAuthn-Spezifikation erlaubt es der Relying Party, in diesem Protokollschritt eine Einstellung oder einen Wert selbst zu setzen.

Security, Privacy oder Accessibility Considerations: Die WebAuthn-Spezifikation beschreibt verschiedene Überlegungen (Considerations), Auswirkungen sowie Maßnahmen in den Bereichen Security, Privacy oder Accessibility.

Neue Anforderung: Die benannte Anforderung ist in der WebAuthn-Spezifikation nicht enthalten, sondern wurde im Rahmen der TR-03188 Passkey Server neu erstellt. Die Rahmenbedingungen für die „Neuen Anforderungen“ werden teilweise von der WebAuthn-Spezifikation oder von der IANA WebAuthn Extensions Registry geschaffen.

⁴ <https://datatracker.ietf.org/doc/html/rfc2119>

3.4.1 Vertrauensniveau normal

Durch die Umsetzung der im Folgenden genannten Maßnahmen kann die Sicherheit eines FIDO-Protokollablaufs in den Angreifermodellen AM-0 und AM-1 sichergestellt werden.

Nr. (AM)	Maßnahmen	Erklärung	SG	Threat
NRM-1	Die Relying Party MUSS HTTPS oder äquivalente Transportsicherung nutzen. (Quelle: § 4 WebAuthn, MUST-Anforderung)	Diese Maßnahme impliziert, dass die Relying Party vertrauenswürdige TLS-Zertifikate ⁵ anbieten muss. Sollte diese Maßnahme nicht umgesetzt werden, können Sicherheitsgarantien verloren gehen.	SG-3	T-1.1.2
NRM-2	Die Werte für "PublicKeyCredentialCreationOptions.challenge" und "PublicKeyCredentialRequestOptions.challenge" MÜSSEN von der Relying Party zufällig in einer vertrauenswürdigen Umgebung generiert werden. Die vom Client zurückgegebene Challenge MUSS mit der generierten Challenge übereinstimmen. Die Relying Party SOLLTE die erstellte Challenge temporär speichern, bis der Authentisierungsvorgang abgeschlossen ist. (Quelle: § 13.4.3 WebAuthn, 1. MUST-Anforderung 2. SHOULD-Anforderung)	Stellt sicher, dass Challenges durch die Relying Party sicher erzeugt und geprüft werden.	SG-1 SG-2	T-2.3.1, T-2.3.2
NRM-3	Challenges SOLLTEN mindestens 16 Byte lang sein. (Quelle: § 13.4.3 WebAuthn, SHOULD-Anforderung, Parameter)	Erhöht die Resistenz der Challenge gegenüber Brute-Force-Angriffen. Zudem sollen Replay Angriffe vermieden werden.	SG-2	T-2.3.2
NRM-4	Das bei der Registrierung festgelegte Signaturverfahren MUSS mindestens ECDSA mit P-256, 2048-bit RSA PSS, RSA-PKCS v1.5, ECDSA mit secp256k1 oder Ed25519 sein. Das verwendete Signaturverfahren SOLLTE konform zu TR-02102-1 sein. (Quelle: § 3.7 FIDO Authenticator Allowed Cryptography List, 1. MUST-Anforderung)	Die Relying Party kann bei der Registrierung eines neuen Credentials angeben, welche Signaturverfahren von dem Authenticator verwendet werden sollen. Während das Protokoll grundsätzlich die Möglichkeit vorsieht, alle Verfahren aus der CBOR Object Signing and Encryption (COSE) Liste auszuwählen, gibt die FIDO	SG-1	-

⁵ Siehe auch: BSI TR-02102-2

Nr. (AM)	Maßnahmen	Erklärung	SG	Threat
	2. Neue Anforderung)	Alliance in der Allowed Cryptography List genau vor, welche Signaturverfahren erlaubt sind.		
NRM-5 (AM-1)	Die Relying Party MUSS sicherstellen, dass durch den Authenticator eine Prüfung der „User Presence“ vorgenommen wurde. Die Relying Party MUSS das „UP“-Flag in der Antwort des Authenticators kontrollieren. (Quelle: § 6.1 WebAuthn, Neue Anforderung)	Wenn ein Authenticator vor Ausstellen einer Assertion eine Prüfung vorgenommen hat, ob ein Benutzer anwesend ist, kann er das „UP“-Flag setzen.	SG-17	T-6.1.1
NRM-6	Die Relying Party DARF den Wert von „user.id“ NICHT von personenbezogenen Daten ableiten. Die „user.id“ SOLLTE zufällig generiert werden. (Quelle: § 14.6.1 WebAuthn, 1. MUST NOT-Anforderung 2. SHOULD-Anforderung)	Stellt sicher, dass durch die Werte von „user.id“ keine Rückschlüsse auf personenbezogene Daten gezogen werden können.	-	-
NRM-7	Die Relying Party MUSS während der Authentisierung sicherstellen, dass durch die Art und Weise, wie mit fehlgeschlagenen Authentisierungsversuchen umgegangen wird, keine Rückschlüsse darauf gezogen werden können, ob Benutzer bei der Relying Party registriert sind. (Quelle: § 13.4.7, § 14.6.2 WebAuthn, Security- and Privacy-Consideration, Neue Anforderung)	Stellt sicher, dass durch das Ausprobieren und Beobachten der Reaktion der Relying Party keine „User Enumeration“ möglich ist. Außerdem soll verhindert werden, dass Accounts mit schwächerem Schutz (Benutzername und Passwort) nicht detektiert werden.	-	-
NRM-8	Die Relying Party SOLLTE es Nutzern erlauben und sie dazu ermutigen, unterschiedlichen Authenticators für denselben Account zu registrieren. Die Relying Party SOLLTE die Optionen „excludeCredentials“ und „user.id“ nutzen, um sicherzustellen, dass diese Credentials zu unterschiedlichen Authenticators gehören. (Quelle: § 13.4.6 WebAuthn, SHOULD-Anforderung, Security-Consideration)	Ermöglicht es Benutzern, alternative Zugangsmöglichkeiten einzurichten.	SG-19	T-6.1.2
NRM-9	Die Relying Party SOLL ermöglichen, dass die Authentisierung wie beispielsweise über Benutzername und Passwort von dem User deaktiviert werden kann, sofern für den betreffenden Account bereits ein FIDO Credential registriert wurde.	Stellt sicher, dass ein Benutzer-Account, der über FIDO-Authentisierung gesichert ist, nicht mittels Passwort-basierter Angriffe kompromittiert werden kann.	-	-

Nr. (AM)	Maßnahmen	Erklärung	SG	Threat
	(Quelle: Neue Anforderung)			
NRM-10	Die Relying Party SOLLTE den Benutzern bei der Registrierung die Möglichkeit geben, zukünftige Autorisierungsgesten korrekt auszuführen. Sofern diese Möglichkeit nicht angeboten wird, MUSS die Relying Party bei der Registrierung eine eindeutige Bezeichnung des verwendeten Authenticators automatisch hinterlegen. (Quelle: § 15 WebAuthn, SHOULD-Anforderung, Accessibility Consideration)	Um Autorisierungsgesten (physikalische Interaktion des Users mit einem Authenticator) korrekt auszuführen, ist der passende Authenticator zu verwendet. Sofern Benutzer mehrere Authenticators besitzen, können diese durch deren Benennung, die Auswahl eines Bildes oder die Eingabe von Freitexten unterschieden werden.	-	-

Tabelle 16: Anforderungen an die Relying Party für das Vertrauensniveau „normal“

3.4.2 Vertrauensniveau substantiell

Durch Erfüllung der im Folgenden genannten Sicherheitsmechanismen kann die Sicherheit eines FIDO-Protokollablaufs zusätzlich in den Angreifermodellen AM-2 und AM-3 sichergestellt werden. Die Anforderungen sind inkrementell zu denjenigen für Vertrauensniveau „normal“ zu verstehen.

Nr. (AM)	Maßnahmen	Erklärung	SG	Threats
SBT-1	Die „Relying Party“ MUSS „userVerification“ während der Erstellung von Credentials und der Erstellung von Assertions auf „required“ setzen und prüfen, ob in der Antwort des Authenticators das „UV“-Flag gesetzt wurde. (Quelle: § 5.4.4 WebAuthn, Parameter)	Ermöglicht es sicherzustellen, dass die Kommunikation mit dem Authenticator tatsächlich auf Anweisung des Benutzers erfolgt.	SG-7, SG-18	T-1.4.3,
SBT-2 (AM-2)	Wenn PIN (Passcode) benutzt wird, dann SOLLTE die Relying Party mithilfe der Extension „minPinLength“ sicherstellen, dass nur Authenticator registriert werden, die eine minimale PIN-Länge für das jeweilige Vertrauensniveau vorweisen. (Quelle: IANA WebAuthn Extension Identifiers, Neue Anforderung)	Damit kann sichergestellt werden, dass ein Mindestmaß an Resistenz gegenüber Brute-Force-Angriffen auf den Authenticator gegeben ist.	SG-7, SG-18	T-1.4.3
SBT-3 (AM-2)	Die Relying Party SOLLTE die „uvm“-Extension verwenden, um festzustellen, welche Benutzerverifikationsmethode verwendet wurde. Insbesondere SOLLTEN „User Verification Method“, „Key Protection Type“ und „Matcher Protection Type“ berücksichtigt werden. (Quelle: IANA WebAuthn Extension Identifiers, Neue Anforderung)	Die Relying Party kann sich vergewissern, dass nur eine als sicher angesehene Benutzerverifikationsmethode verwendet wurde und das gespeicherte Schlüsselmaterial optimal geschützt wird.	SG-18	T-1.4.3
SBT-4 (AM-3)	Die Relying Party MUSS Account-Wiederherstellung über ein Verfahren anbieten, das einer Authentisierung auf dem Vertrauensniveau „substantiell“ oder höher entsprechen. Insbesondere DARF Passwort- oder E-Mail-basierte Wiederherstellung NICHT angeboten werden. (Quelle: Neue Anforderung)	Damit kann ein einheitliches Vertrauensniveau für den betreffenden Account sichergestellt werden.	SG-19	T-6.1.2
SBT-5 (AM-2)	Die Relying Party SOLLTE bei der Registrierung keine Authenticator akzeptieren, der die Extension „minPinLength“ nicht unterstützt, wenn PIN (Passcode) benutzt wird. (Quelle: IANA WebAuthn Extension Identifiers, Neue Anforderung)	Fordert das Vorhandensein dieser Extension bereits bei der Registrierung eines Authenticators, sodass die Extension bei der Erstellung einer Assertion auch tatsächlich verwendet werden kann.	SG-18	T-1.4.3

Nr. (AM)	Maßnahmen	Erklärung	SG	Threats
SBT-6	Der Authenticator MUSS eine Form der Attestation bereitstellen. Die Relying Party MUSS diese Attestation verifizieren. (Quelle: § 6.5, §7 WebAuthn, 1. SHOULD-Anforderung, 2. MUST-Anforderung)	Damit wird sichergestellt, dass genannte Eigenschaften (UV-Flag) übermittelt und von der Relying Party überprüft werden.	SG-1	T-1.2.3

Tabelle 17: Anforderungen an die Relying Party für das Vertrauensniveau „substantiell“.

3.4.3 Vertrauensniveau hoch

Durch Erfüllung dieser Sicherheitsmechanismen kann ein FIDO-Protokollablauf gegen das Angreifermodell AM-6 abgesichert werden, indem Device Bound Passkeys verwendet werden. Die Anforderungen sind inkrementell zu denjenigen für das Vertrauensniveau „substantiell“ zu verstehen. Ein Schutz gegen Angreifermodelle AM-4 und AM-5 kann, wie bereits erläutert, aktuell nicht sichergestellt werden.

Nr. (AM)	Maßnahmen	Erklärung	SG	Threats
HCH-1 (AM-6)	Die Relying Party MUSS über ein gültiges Attestation Object und die darin enthaltene AAGUID sicherstellen, dass der verwendete Authenticator über bestimmte Sicherheitsfunktionen verfügt und Device Bound Passkeys verwendet, z.B. min. L3 ⁶ Authenticator. (Quelle: § 6 WebAuthn, Neue Anforderung)	Damit kann sichergestellt werden, dass der verwendete Authenticator bestimmte Eigenschaften erfüllt. Die Prüfung des Zertifizierungslevels erfolgt anhand der Informationen aus dem FIDO Metadata Statement auf Basis einer vertrauenswürdig attestierten AAGUID.	SG-9, SG-21	T-1.4.1, T-6.1.4
HCH-2 (AM-6)	Der Authenticator MUSS ein Attestation Statement bereitstellen. Dabei MUSS „direct“ oder „enterprise“ Attestation in den Varianten Basic, AttCA oder AnonCA verwendet werden. Die Prüfung der Signatur des „Attestation Statements“ MUSS für die gesamte Signaturkette bis zur CA erfolgreich sein. (Quelle: § 7.1 WebAuthn, Parameter, SHOULD-Anforderung)	Damit kann sichergestellt werden, dass eine Prüfung von Eigenschaften (wie FIDO-Zertifizierungslevel) des Authenticators über das Attestation Statement möglich ist.	SG-9, SG-21	T-1.4.1, T-6.1.4
HCH-3	Wenn die Prüfung eines Attestation Statements während eines Authentisierungsvorgangs aufgrund eines zurückgezogenen CA-Zertifikats fehlschlägt, MUSS die Relying Party den Registrierungs- und Authentisierungsvorgang ablehnen. (Quelle: § 13.4.5 WebAuthn, Security-Consideration)	Die Gültigkeit der Attestation kann von der RP nicht mehr geprüft werden, weswegen keinerlei verlässliche Informationen über die Sicherheitseigenschaften des verwendeten Authenticators mehr abgeleitet werden können.	-	-
HCH-4	Die Relying Party SOLLTE die „loc“-Extension verwenden, um den aktuellen Standort des Authenticators bzw. des Clients zu bestimmen. Diese Information SOLLTE für risikobasierte Authentisierung verwendet werden. (Quelle: IANA WebAuthn Extension Identifiers, Neue Anforderung)	Die Relying Party kann eine auffällige Änderung des Ortes der Verwendung des Authenticators feststellen und ggf. weitere Sicherheitsmaßnahmen einleiten.	-	-

⁶ Siehe auch: <https://fidoalliance.org/certification/authenticator-certification-levels/>

Nr. (AM)	Maßnahmen	Erklärung	SG	Threats
HCH-5 (AM-5)	Die Relying Party SOLLTE nur Assertions akzeptieren, bei denen der Parameter „tokenBinding“ gesetzt ist. Die Relying Party MUSS prüfen, dass der in dem Parameter übermittelte Wert zu dem über TLS erstellten Token Binding passend ist. (Quelle: § 5.1.4.1 WebAuthn, Parameter)	Sofern der Client kein valides Token Binding übermitteln kann, kann dies ein Hinweis darauf sein, dass ein MitM-Angriff auf die TLS-Verbindung zwischen Client und Relying Party durchgeführt wird.	SG-11 SG-12 SG-13	T-3.1.2, T-3.1.3
HCH-6 (AM-4)	Die Relying Party MUSS einen zusätzlichen Authentisierungsvorgang durchführen, wenn der Benutzer sicherheitskritische Transaktionen auslösen will (bspw. die Änderung eines Passworts). Die Relying Party SOLLTE die „txAuthSimple“-Extension verwenden, um Informationen über die durchzuführende Transaktion an den Benutzer zu übermitteln. (Quelle: IANA WebAuthn Extension Identifiers, Neue Anforderung)	Damit kann sichergestellt werden, dass sicherheitskritische Transaktionen nicht ohne Wissen und expliziter Bestätigung des Benutzers durchgeführt werden können. Erfordert einen anderen gesicherten Kanal, z. B. dass der Authenticator ein Display hat, über den Informationen an den Benutzer übermittelt werden können.	SG-20	T-1.2.5, T-2.2.1, T-6.1.3
HCH-7 (AM-4)	Die Relying Party SOLLTE bei der Registrierung keine Authenticators akzeptieren, die die Extension „txAuthSimple“ nicht unterstützen. (Quelle: IANA WebAuthn Extension Identifiers, Neue Anforderung)	Damit kann sichergestellt werden, dass alle Anforderungen für das Vertrauensniveau „hoch“ erfüllt werden können.	SG-20	T-6.1.3

Tabelle 18: Anforderungen an die Relying Party für das Vertrauensniveau „hoch“. Aktuell nicht erfüllbare Anforderungen sind mit roter Farbe hinterlegt.

3.5 Weitere Aspekte

3.5.1 Nicht berücksichtigte Konfigurationsoptionen

Neben den bereits betrachteten MUST-, SHOULD-, und MAY-Anforderungen, gibt es in der FIDO-Spezifikation noch weitere Konfigurationsoptionen, mit denen Einfluss auf einen Authentifizierungsvorgang genommen werden kann, die aber keine unmittelbare Auswirkung auf dessen Sicherheit haben.

<i>Konfigurationsoption</i>	<i>Beschreibung</i>
„timeout“ (§ 5.1.3, § 5.1.4.1 WebAuthn)	Sowohl bei der Registrierung als auch bei der Erstellung einer Assertion kann die Relying Party dem Client einen Hinweis dazu geben, welchen Zeitraum sie für die Beantwortung der Anfrage für angemessen hält. Der Client ist jedoch nicht verpflichtet, sich an diesen Wert zu halten. Empfohlene Werte variieren und werden mit 120.000 Millisekunden (2 Minuten) und 300.000 Millisekunden (5 Minuten) angegeben. Die Relying Party könnte Registrierung- und Assertion-Vorgänge nach diesem definierten Zeitraum abbrechen.
„AuthenticatorAttachment“ (§ 5.4.5 WebAuthn)	Die Relying Party kann bei der Registrierung eines neuen Credentials angeben, ob der verwendete Authenticator ein Plattform-Authenticator sein soll, oder nicht. Dabei ist allerdings zu beachten, dass diese Option für die Erstellung von Assertions nicht existiert und von dem Client auch nicht befolgt werden muss. Optionen, die von der Relying Party dazu gesetzt werden können, sind "platform" und "cross-platform".
„ResidentKeyRequirement“ (§ 5.4.6 WebAuthn)	Die Relying Party kann bei der Registrierung angeben, ob das erstellte Credential client- oder serverseitig erzeugt werden soll.
„transports“ in der Datenstruktur „PublicKeyCredentialDescriptor“ (§ 5.10.4 WebAuthn)	Die Relying Party kann ihre Präferenz dazu kommunizieren, über welche Verbindungsart mit dem Authenticator kommuniziert werden soll (bspw. NFC oder USB). Der Client ist nicht verpflichtet dieser Empfehlung zu folgen. Möglich Werte sind hier "usb", "nfc", "ble" und "internal".

Tabelle 19: Weitere Konfigurationsoptionen.

3.5.2 Sicherheits- und Datenschutzüberlegungen

Die WebAuthn-Spezifikation diskutiert in den Kapiteln 13 („Security Considerations“) und 14 („Privacy Considerations“) die Auswirkungen verschiedener Entwurfsentscheidungen auf die Sicherheit und den Datenschutz. Hierbei werden auch Maßnahmen und Mechanismen betrachtet, die ergänzend zu der WebAuthn-Spezifikation genutzt werden können. Im Folgenden werden diese Überlegungen im Einzelnen dargestellt und der jeweilige Einfluss auf die Relying Party diskutiert. Sofern diese Überlegungen als Maßnahme in einem Vertrauensniveau überführt wurde, wird dieses ebenfalls dargelegt.

3.5.2.1 Security Considerations

<i>Überlegung</i>	<i>Beschreibung</i>	<i>Überführte Maßnahmen</i>
„Credential ID Unsigned“	Die vom Authenticator übertragene „Credential ID“ ist nicht Teil der signierten Daten, wodurch es einem MitM-Angreifer grundsätzlich möglich sein kann, diese zu manipulieren. Bei der „Credential ID“ handelt es sich aber nicht um ein schützenswertes Datum, da eine Manipulation nur zur Folge hat, dass der Authentisierungsvorgang fehlschlägt, was ein MitM-Angreifer ohnehin auch auf anderem Wege erreichen kann.	Keine.
„Physical Proximity between Client and Authenticator“	Das WebAuthn-Authenticator-Modell sieht vor, dass sich selbst Roaming Authenticators immer physisch nahe am Client befinden und direkt mit dem Client kommunizieren. Das hat den Vorteil, dass auch potentielle Angreifer physisch Zugriff auf den Authenticator haben müssen, um damit interagieren zu können. Für Systemarchitekturen, in denen diese physische Nähe nicht gewährleistet werden kann, müssen dadurch entstehende Sicherheitsnachteile berücksichtigt werden.	Abgebildet in Anforderung HCH-4.
„Attestation Certificate Hierarchy“	Für Attestation-Zertifikate wird eine dreistufige Zertifikathierarchie empfohlen. Jedes Authenticator-Modell sollte dabei eine eigene CA haben.	Keine, da nur auf Hersteller von Authenticators anwendbar.
„Attestation Certificate Compromise“	Wenn ein Attestation-CA-Zertifikat kompromittiert wird, besteht die Möglichkeit, die einzelnen Attestation-Schlüssel der betroffenen Authenticators neu zu signieren. Wenn ein einzelner Attestation-Schlüssel eines Authenticators kompromittiert wird, muss dieser von der herausgebenden CA widerrufen werden.	Indirekt abgebildet in Anforderung HCH-3.

Überlegung	Beschreibung	Überführte Maßnahmen
„Security Benefits for WebAuthn Relying Parties“	Beschreibt die Vorteile, die durch die Nutzung von FIDO2 entstehen. Die genannten Sicherheitsvorteile gelten nur, wenn die Anforderungen aus Kapitel 7 („WebAuthn Relying Party Operations“) korrekt umgesetzt werden.	Alle sicherheitsrelevanten MUST-Anforderungen sind bereits ab Vertrauensniveau „normal“ gefordert. Alle funktionalen Anforderungen müssen ohnehin umgesetzt werden.
„Visibility Considerations for Embedded Usage“	Wenn das Benutzerinterface eines WebAuthn-Authentisierungsvorgangs in eine Webseite eingebettet wird (bspw. über iframes), kann das zu Clickjacking-Schwachstellen führen. In der Praxis ist das allerdings in den meisten Fällen kein Problem, da das Benutzerinterface von dem Client direkt angezeigt wird und nicht Teil der Webseite ist.	Keine.
„Cryptographic Challenges“	Die Sicherheit eines FIDO-Authentisierungsvorgangs ist maßgeblich von der Entropie des durch die RP erstellten Zufalls abhängig. Challenges sollten dementsprechend ausreichend lang sein, um ein Erraten zu verhindern.	Abgebildet in Anforderung NRM-3.
„Attestation Limitations“	Die Verwendung von Attestation unterliegt bestimmten Einschränkungen. So kann ein MitM-Angreifer ein beim Registrierungsvorgang übertragenes Attestation Statement grundsätzlich gegen ein anderes Statement austauschen, um die RP so über die Art des verwendeten Authenticators zu täuschen. Die Relying Party kann dabei helfen, derartige Angriffe aufzudecken, indem sie keine „Self Attestation“ erlaubt und dem Benutzer alle Informationen zu dem für die Registrierung verwendeten Authenticator anzeigt.	Nutzung von „Self Attestation“ ab Vertrauensniveau „hoch“ durch Prüfung der Zertifikatskette ausgeschlossen (HCH-2).
„Revoked Attestation Certificates“	Wenn die Validierung eines Attestation-Zertifikats aufgrund eines zurückgezogenen CA-Zertifikats fehlschlägt, sollte das betreffende Credential gesperrt werden.	Abgebildet in Anforderung HCH-3.
„Credential Loss and Key Mobility“	Im Allgemeinen besteht die sicherheitsrelevante Annahme, dass der private Schlüssel eines Credentials den Authenticator, auf dem er erstellt wurde, nie verlässt. Der Verlust dieses Schlüssels kann daher zum vollständigen Verlust des zugehörigen Benutzerkontos führen. Aus diesem Grund sollten RP die Möglichkeit anbieten, mehrere Credentials für den gleichen Account zu registrieren.	Abgebildet in Anforderung NRM-9.

Überlegung	Beschreibung	Überführte Maßnahmen
„Unprotected Account Detection“	Bei der Verwendung von „Non-Resident Keys“ muss darauf geachtet werden, dass keine Informationen über bei der RP registrierte Benutzerkonten leaked werden. Beispielsweise könnte die RP für ein Benutzerkonto mit einer „Credential ID“ antworten und für ein anderes Benutzerkonto (für das kein FIDO-Credential registriert wurde) mit einer Passwortabfrage.	Abgebildet in Anforderung NRM-8.

Tabelle 20: Zusammenfassung der Security Considerations aus der WebAuthn-Spezifikation.

3.5.2.2 Privacy Considerations

Überlegung	Beschreibung	Überführte Maßnahmen
„De-anonymization Prevention Measures“	Obwohl ein FIDO2-Protokollablauf explizit keine spezifischen Informationen enthält, die die Identifizierung von einzelnen Benutzenden erlauben, werden technisch bedingt verschiedene Informationen übertragen, die möglicherweise eine Korrelation erlauben.	Keine. Die Überlegungen sind reine Aufzählung ohne Handlungsempfehlung.
„Anonymous, Scoped, Non-correlatable Public Key Credentials“	„Credential IDs“ und „Credential Public Keys“ müssen zwar mit der RP geteilt werden, sie sind jedoch so entworfen, dass sie nur die minimal notwendige Menge an identifizierenden Informationen erfordern.	Keine. Die Überlegungen sind reine Aufzählung ohne Handlungsempfehlung.
„Authenticator-local Biometric Recognition“	Einige Authenticators haben die Möglichkeit, selbst eine biometrische Erkennung des Benutzers vorzunehmen. Sofern die Relying Party im Rahmen eines Authentisierungsvorgangs eine biometrische Prüfung durchführen möchte, kann sie diese an den Authenticator auslagern.	Keine, da die Anwendbarkeit einzelfallabhängig ist.
„Attestation Privacy“	Über Attestation-Zertifikate lassen sich ggf. Verwendungen des gleichen Authenticators über verschiedene Benutzerkonten und Plattformen hinweg feststellen und somit weitere Informationen über Benutzende ermitteln. Um dies zu verhindern, kann auf die Erstellung von Authenticator-individuellen Attestation-Zertifikaten verzichtet und stattdessen mehrere Authenticators mit dem gleichen Zertifikat versehen werden.	Keine, da nur auf Hersteller von Authenticators anwendbar.

Überlegung	Beschreibung	Überführte Maßnahmen
„Privacy of Personally Identifying Information Stored in Authenticators“	Authenticators können grundsätzlich neben den in der Spezifikation geforderten Daten noch weitere (ggf. personenbezogene) Daten speichern. In diesem Fall sollte Sorge getragen werden, dass diese zusätzlichen Daten nicht gegenüber unbefugten Dritten exponiert werden.	Keine, da nur auf Hersteller von Authenticators anwendbar.
„Registration Ceremony Privacy“	Clients sollten darauf achten, keine Informationen zu vorhandenen Authenticators preiszugeben, solange der zugehörige Authenticator noch nicht für die Registrierung bei einer RP verwendet wurde.	Keine, da nur auf den Client anwendbar.
„Authentication Ceremony Privacy“	Clients sollten darauf achten, keine Informationen zu auf einem Authenticator gespeicherten Credentials preiszugeben (bspw. durch automatisiert ausgelöste Fehlnachrichten), bevor der Benutzer einer Interaktion mit einer RP nicht ausdrücklich zugestimmt hat.	Keine, da nur auf den Client anwendbar.
„User Handle Contents“	Der von der RP gesetzte „user handle“ (entspricht dem Wert von „user.id“) darf keine personenbezogenen Daten enthalten und darf auch nicht von personenbezogenen Daten abgeleitet sein.	Abgebildet in Anforderung NRM-7.
„Username Enumeration“	Durch Art der (Fehler-)Meldungen, die eine RP zurückgibt, wenn ein bestimmter Benutzeraccount existiert oder nicht existiert, kann ein Angreifer ggf. Informationen darüber erhalten, welche Benutzer bei einer RP registriert sind - beispielsweise, wenn für einen Benutzernamen eine Fehlermeldung angezeigt wird, dass dieser Benutzer nicht vorhanden ist, und für einen anderen eine FIDO2-Authentication-Ceremony gestartet wird.	Abgebildet in Anforderung NRM-8.
„Privacy Leak via Credential IDs“	Durch die Übermittlung einer „Credential ID“ von der RP an den Client kann es dazu kommen, dass Informationen über bei der RP registrierte Benutzeraccounts preisgegeben werden. Das ist beispielsweise der Fall, wenn ein Angreifer die RP nur auf Basis einer E-Mail-Adresse dazu bringt, einen Authentisierungsvorgang einzuleiten und die zu der Adresse gespeicherte Credential ID an den Client zu übertragen.	Keine, da Credential IDs zufällig erstellt werden und nicht untereinander korrelierbar sind.

Tabelle 21: Zusammenfassung der Privacy Considerations aus der WebAuthn-Spezifikation.

3.5.3 Übersicht über die FIDO-Extensions

Die IANA WebAuthn Extension Registry listet zahlreiche FIDO-Erweiterungen auf. Da diese Extensions teilweise in den verschiedenen Vertrauensniveaus aufgeführt sind, werden diese in der folgenden Übersicht dargestellt sowie deren Sicherheitsrelevanz eingeordnet.

WebAuthn Extension	Beschreibung	Sicherheitsrelevanz
appid	Wird von „Relying Parties“ genutzt, die ein Credential verwenden wollen, dass über eine Legacy-API erzeugt wurde.	Keine, die Extension hat für die Praxis keine Bedeutung mehr.
txAuthSimple	Kann von der „Relying Party“ genutzt werden, um zusätzliche Informationen über die Art der autorisierten Transaktion an den Authenticator zu übermitteln. Erfordert einen Authenticator mit Display.	Die Verwendung dieser Extension kann Angriffe von kompromittierten „User Devices“ oder „Relying Party Apps“ maßgeblich erschweren, da sie dem Benutzer die Möglichkeit gibt, vor der Erstellung einer Assertion auf einem Gerät, dem er vertraut, zu validieren, dass tatsächlich die gewünschte Interaktion mit der gewünschten Webseite durchgeführt werden soll.
txAuthGeneric	Funktioniert wie „txAuthSimple“, es können jedoch beliebige Daten, nicht nur Text, übertragen werden. Erfordert jedoch wesentlich komplexere Anzeigefähigkeiten auf Seiten des Authenticators.	Wie bei „txAuthSimple“.
authnSel	Ermöglicht der „Relying Party“, Hinweise zur Auswahl des Authenticators für die Erstellung eines Credentials zu übermitteln.	Spielt nur eine Rolle, wenn der Benutzer mehrere Authenticators parallel in Betrieb hat. Der Hinweis der Relying Party muss auch nicht befolgt werden, sodass hier keine Sicherheitsvorteile zu erwarten sind.
exts	Ermöglicht der „Relying Party“ zu identifizieren, welche Extensions von einem Authenticator unterstützt werden.	Kann dabei helfen, bestimmte Authenticators abzulehnen, die bspw. „User Verification“ nicht unterstützen, und damit ein insgesamt höheres Sicherheitsniveau zu erreichen. Authenticators, die im FIDO-Metadata-Statement eingetragen sind, können auch darüber identifiziert werden.
uvi	Kann von der „Relying Party“ genutzt werden, um abzufragen, welche „User Verification“ vom Authenticator zur Erstellung einer Assertion genutzt wurde. Relevant, sofern der Authenticator bspw. mehrere Benutzer mit unterschiedlichen biometrischen Merkmalen unterstützt.	Grundsätzlich sicherheitsrelevant, allerdings existieren in der Praxis nur sehr wenige derartige Authenticators. In der Regel unterstützen Authenticators immer nur genau einen Benutzer für die „User Verification“.

WebAuthn Extension	Beschreibung	Sicherheitsrelevanz
loc	Überträgt den aktuellen Standort des „User Device“ an die „Relying Party“.	Diese Extension kann von der „Relying Party“ als zusätzliche Information für „Risk-based Authentication“ genutzt. So können z.B. Authentisierungsanfragen aus Ländern, aus denen sich der Benutzer normalerweise nicht anmeldet, blockiert werden.
uvm	Teilt der „Relying Party“ mit, welche Art der „User Verification“ (z.B. PIN oder Fingerabdruck) genutzt wurde.	Kann dazu genutzt werden, besonders sichere Verifikationsverfahren einzufordern. Beispielsweise kann es Szenarien geben, bei denen die Authentisierung über einen Fingerabdruck sicherer sein kann als die Verwendung einer vierstelligen PIN.
credProtect	Mit dieser Extension kann die „Relying Party“ dem Authenticator mitteilen, welche Präferenzen sie bezüglich des Schutzes, der auf dem Authenticator gespeicherten Credentials hat.	Kann dazu genutzt werden, dem Authenticator mitzuteilen, dass Credentials durch „User Verification“ geschützt werden müssen. Die Umsetzung kann jedoch von der „Relying Party“ nicht verifiziert werden, weswegen dafür andere Mechanismen geeigneter erscheinen (bspw. die Prüfung des Metadata Statetements oder Attestation).
credBlob	Diese Extension erlaubt es der „Relying Party“, eine geringe Menge an zusätzlichen Konfigurationsdaten an den Authenticator zu übertragen.	Ist in seiner aktuellen Ausprägung nicht sicherheitsrelevant, da damit aktuell keine sicherheitsrelevanten Funktionen umgesetzt werden. Könnte aber grundsätzlich dafür verwendet werden.
largeBlobKey	Erlaubt es plattformbasierten Authenticatoren, einen Account-individuellen Schlüssel zu speichern, mit dem „largeBlob“-Datenstrukturen entschlüsselt werden können.	Wird aktuell nicht für die Realisierung von sicherheitsrelevanten Funktionen verwendet, eignet sich aber grundsätzlich dafür, vertrauliche Daten bei der „Relying Party“ abzulegen, womit ggf. zusätzliche sicherheitsrelevante Funktionen implementiert werden könnten.
minPinLength	Kann von der RP bei der Registrierung dazu verwendet werden, die Länge der aktuell gesetzten PIN zu ermitteln.	Durch Verwendung dieser Extension kann ein höheres Schutzniveau für das Entsperren des Authenticators erzwungen werden, indem entsprechende Registrierungsversuche abgelehnt werden.
hmac-secret	Ermöglicht es dem Client, einen symmetrischen Schlüssel, der einem Credential zugeordnet ist, vom Authenticator generieren zu lassen.	Kann grundsätzlich vom Client dafür genutzt werden, Daten symmetrisch zu verschlüsseln, hat aber keine Auswirkung auf die Sicherheit der Interaktion mit der Relying Party.
appidExclude	Ermöglicht es der RP, Authenticators abzulehnen, die noch Credentials verwalten, die mit der veralteten FIDO2F-Javascript-API erstellt wurden.	Ist grundsätzlich sicherheitsrelevant, allerdings existieren derartige Credentials in der Praxis nicht mehr.

WebAuthn Extension	Beschreibung	Sicherheitsrelevanz
credProps	Ermöglicht es dem Client, der RP bei der Registrierung zusätzliche Informationen über das erstellte Credential zu übermitteln.	Zum aktuellen Zeitpunkt scheint es keinen sicherheitsrelevanten Anwendungsfall zu geben.
largeBlob	Ermöglicht es dem Client, bei der Registrierung zusätzliche Daten bei der RP abzulegen.	Wird aktuell nicht für die Realisierung von sicherheitsrelevanten Funktionen verwendet, eignet sich aber grundsätzlich dafür, vertrauliche Daten bei der „Relying Party“ abzulegen, womit ggf. zusätzliche sicherheitsrelevante Funktionen implementiert werden könnten.
payment	Ermöglicht die Verwendung von FIDO2 in Kombination mit der Secure Payment Confirmation API.	Kann nicht zur Realisierung von zusätzlichen Sicherheitsfunktionen bei einem normalen FIDO-Protokollablauf verwendet werden.

Tabelle 22: Übersicht über alle bei IANA registrierten WebAuthn-Erweiterungen.

4 Handlungsempfehlung

Dieser Abschnitt beschreibt die Integrationsmöglichkeiten für Passkey Server (FIDO2 Server) basierend auf den Erkenntnissen einer Marktsichtung und den Ergebnissen einer technischen Analyse. Ziel ist die Erstellung einer **Handlungsempfehlung**, die kleinen und mittleren Webseitenbetreibern bei der Auswahl einer geeigneten Integrationslösung für FIDO2 auf ihren Webseiten unterstützt. Zudem soll diese Handlungsempfehlung als Grundlage für eine Kosten-Nutzen-Analyse dienen. Hierfür wird zunächst eine Beschreibung und Gegenüberstellung der gängigen Integrationsmöglichkeiten von FIDO2 Servern vorgenommen und anschließend werden die jeweiligen Vor- und Nachteile erläutert.

4.1 Integrationsmöglichkeiten

Aufgrund der zahlreichen Ausprägungen und Integrationsmöglichkeiten von Passkey Servern (FIDO2 Servern) erscheint es zweckmäßig, diese entsprechend zu klassifizieren. Anhand der Ergebnisse der Marktsichtung lassen sich die am Markt verfügbaren FIDO2 Server in die in Abbildung 8 dargestellten Kategorien einteilen.

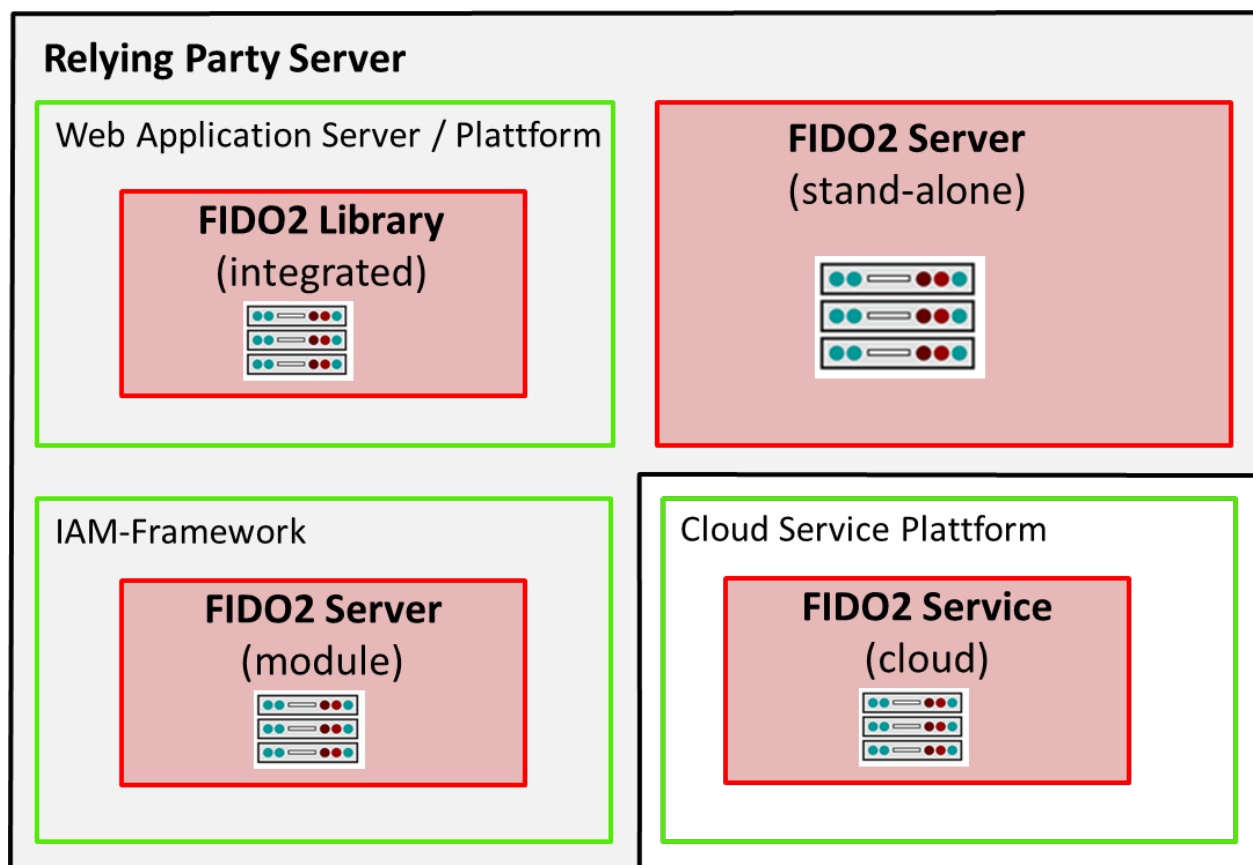


Abbildung 8: Integrationsmöglichkeiten für FIDO2 Server

Die Kategorie **FIDO2 Library (integrated)** zeichnet sich dadurch aus, dass der FIDO2 Server als Bibliothek (Library) realisiert ist, die in geeigneten Web Application Servern (z.B. Java) oder auf gängigen Web Application Plattformen (z.B. JavaScript, Python, PHP, Ruby, Go) lauffähig ist.

Bei **FIDO2 Server (stand-alone)** ist der FIDO2 Server als eigenständiges Serversystem realisiert, das beispielsweise über eine REST-basierte Schnittstelle angesprochen wird.

Die Ausprägung **FIDO2 Server (module)** ist dadurch charakterisiert, dass der FIDO2 Server als Modul in einem übergreifenden Identity Access Management-Framework integriert ist und dort beispielsweise über eine OpenID Connect Schnittstelle bzw. teilweise über SAML integriert werden kann.

Bei **FIDO2 Service (cloud)** ist der FIDO2 Server Teil einer Cloud Service Plattform und kann dort z.B. über OpenID Connect bzw. teilweise über SAML als Dienst bezogen werden.

4.2 Gegenüberstellung der verschiedenen Integrationsmöglichkeiten

Für eine Gegenüberstellung der verschiedenen Integrationsmöglichkeiten von FIDO2 -Servern werden sowohl qualitative als auch quantitative Merkmale bzw. das vorhandene Leistungsspektrum ermittelt und miteinander verglichen. Hierfür werden die Ergebnisse aus einer vorangegangenen Marktsichtung sowie einer technischen Analyse herangezogen.

4.2.1 Aufwand der Integration

Beim Aufwand der Implementierung bzw. Inbetriebnahme gab es deutliche Unterschiede, zwischen wenigen Stunden bis zu mehreren Tagen.

Um die Testbedingungen möglichst zu vereinheitlichen, wurde im Rahmen der technischen Analyse eine Testumgebung auf Basis von Containern entwickelt, auf der die meisten FIDO2 Server installiert wurden. Der grobe Aufbau der Infrastruktur ist in Abbildung 9 dargestellt. Für zwei Systeme musste auf dedizierte virtuelle Maschinen zurückgegriffen werden, da eine Installation mit Containern nicht unterstützt bzw. technisch nicht möglich war.

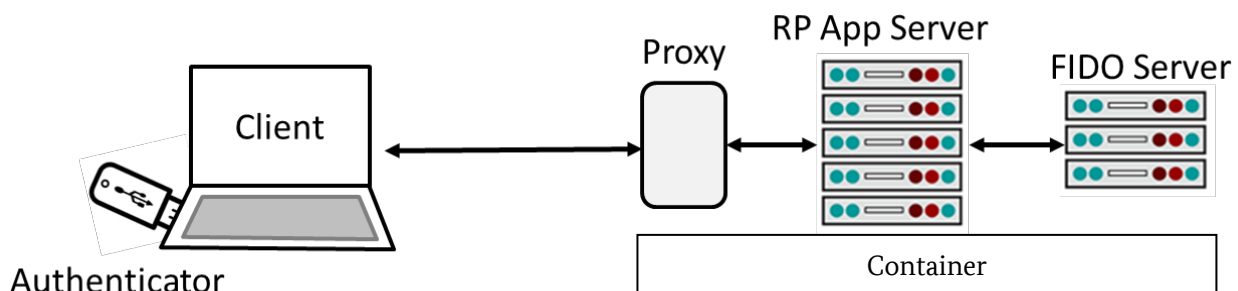


Abbildung 9: Aufbau der Infrastruktur zur technischen Untersuchung der FIDO2 Server

Während der technischen Analyse wurde für jeden FIDO2 Server eine Testanwendung (Relying Party, RP) installiert und konfiguriert, um den Integrationsaufwand besser einschätzen zu können. In den meisten Fällen waren diese entweder im Installationspaket des FIDO2 Servers vorhanden oder es konnte auf Quellcode zurückgegriffen werden, den die Firmen als Open Source veröffentlicht haben, um die Anbindung an ihr Produkt zu demonstrieren und zu vereinfachen.

Neben den technischen Herausforderungen traten teilweise auch organisatorische Hürden vor dem Einsatz der FIDO2 Server auf. So war es in einigen Fällen notwendig, Geheimhaltungserklärungen (NDAs) zu unterzeichnen, bevor der Zugang zur Software oder zur Dokumentation gewährt wurde – eine potenzielle Barriere, die für private Endanwender und kleinere Unternehmen schwer zu überwinden sein dürfte.

Tabelle 23 zeigt den ungefähren Aufwand, der benötigt wurde, um eine Testanwendung zu installieren und so zu konfigurieren, dass der jeweilige FIDO2 Server funktionsfähig ist und die Tests durchgeführt werden konnten. Da bei Cloudlösungen die Installation entfällt, sind hier keine Angaben vorhanden.

Integrationsart	Aufwand für die Installation*	Aufwand für die Konfiguration*
„Bibliothek“	Eher einfach	Einfach
„Stand-alone“	Aufwendig	Eher aufwendig
„Module“	Eher einfach	Eher aufwendig
„Cloud“	Keine	Eher einfach

Tabelle 23: Aufwand für Installation und Konfiguration

* einfach: ≤ 4 Stunden, eher einfach: 5-8 Stunden, eher aufwendig: 9-12 Stunden, aufwendig: >12 Stunden

Bei diesen Werten ist zu beachten, dass es sich nur um Richtwerte handelt. Nicht enthalten sind die Suche nach einer geeigneten Testanwendung sowie die Zeit für das Aufsetzen einer virtuellen Maschine. Zudem handelt es sich jeweils nur um Anwendungen, die die grundlegende Funktionalität demonstrieren sollen. Eine Integration in bestehende, komplexe Anwendungen oder die Neuentwicklung einer umfangreichen FIDO2 Lösung dürfte einen entsprechend höheren Zeitaufwand bedeuten.

4.2.2 Konfigurierbarkeit

Die meisten FIDO2 Server bieten eine Reihe von Konfigurationsoptionen, mit denen das Verhalten des Servers angepasst werden kann. Ob und welche Optionen benötigt werden, ist stark von individuellen Bedürfnissen abhängig und sollte im Vorfeld abgeklärt werden.

Die Konfigurationsmöglichkeiten der untersuchten FIDO2 Server waren sehr unterschiedlich. Während bei einigen Installationen nur minimale Anpassungen möglich waren, gab es auf der anderen Seite Server, bei denen sehr umfangreiche Einstellungsmöglichkeiten vorhanden waren.

Bei den Bibliotheken konnte über das Setzen bestimmter Konfigurationsoptionen (z.B. User Verification oder Attestation) Einfluss auf die FIDO2 Registrierung und Authentisierung genommen werden. Ähnlich verhält es sich bei den Stand-alone und den modularen FIDO2 Servern, nur dass dies hier in der Regel in der grafischen Benutzeroberfläche möglich ist. In einem untersuchten Fall eines modularen FIDO2 Servers konnten darüber hinaus beliebig komplexe Richtlinien in einem Policy Manager eingerichtet werden. Die Konfigurierbarkeit von Cloudanwendungen dagegen war eher eingeschränkt. In einem Fall gab es keinerlei Konfigurationsmöglichkeiten.

4.2.3 Funktionsumfang

Wie zu erwarten ist der Funktionsumfang zwischen den einzelnen Integrationsmöglichkeiten, aber auch innerhalb der jeweiligen Gruppe unterschiedlich ausgeprägt. So muss bei allen Bibliotheken die Filterung nach AAGUIDs (Authenticator Attestation Globally Unique Identifier) stets selbst implementiert werden. Grundlegende Funktionen und Datenstrukturen für den Umgang mit AAGUIDs sind jedoch meistens vorhanden. Während alle im Rahmen der Marktsichtung untersuchten modularen FIDO2 Server die Filterung nach AAGUIDs unterstützten, war dies bei den beiden anderen Integrationsarten (Stand-alone und Cloud) nicht immer der Fall.

Nur sehr wenige der FIDO2 Bibliotheken bieten Support für den Metadata Service (MDS) der FIDO-Alliance. Das Feature "User Verification" wird von allen analysierten Bibliotheken unterstützt. Alle Bibliotheken sind als Open Source verfügbar und nutzen liberale Lizenzen wie BSD 3-Clause, Apache 2.0 oder MIT License.

Etwas besser als bei den Bibliotheken sieht es bei den FIDO2 Stand-alone Servern in Bezug auf den Metadata-Service (MDS) aus. Häufig werden die Produkte unter einer proprietären Lizenz bereitgestellt, Open Source Lizenzen wie LGPLv2 und Apache 2.0 sind eher die Ausnahme.

Während bei den FIDO2 Bibliotheken keinerlei Angaben gemacht wurden, welche FIDO2 Authenticators unterstützt werden, ist bei den anderen Integrationsarten das Gegenteil der Fall. Hier geben nahezu alle Anbieter an, zumindest die von der FIDO-Alliance zertifizierten Geräte zu unterstützen.

Bei keiner der FIDO2 Bibliotheken gibt es Hinweise darauf, welche Level der WebAuthn Spezifikation genau implementiert wurden (Level 1, 2 oder 3). Ähnlich verhält es sich bei den Cloudanbietern. Bei den Stand-alone Servern wurden nicht immer Angaben gemacht, ein Teil gab an, Level 2 zu unterstützen. Bei den modularen FIDO2 Servern geben fast alle einen Support für Level 2 an.

Alle FIDO2 Server in der Kategorie „module“ bieten neben REST eine IAM-Schnittstelle über OpenID Connect an, die in der Regel auch SAML unterstützt. Fast alle Server sind FIDO-zertifiziert, in seltenen Fällen liegt zudem eine FIPS 140 Konformität im Status "experimentell" vor. Das "User Verification" Feature und die AAGUID-Filterung werden von allen Servern unterstützt. Die Mehrheit der Server nutzt den Metadaten dienst der FIDO-Alliance.

Alle Anbieter der betrachteten Cloudservices geben an, dass sie „FIDO certified“ sind. Einzelne Angebote eignen sich sowohl für die Bereitstellung als Dienst als auch für die lokale Installation im eigenen Rechenzentrum („On-Premise“). Das „User Verification“ Feature wird von allen unterstützt, wobei AAGUID-Filterung eher die Ausnahme ist. Bezüglich der Sicherheitseigenschaften wurde mehrfach auf eine Verfügbarkeit von 99,95 % hingewiesen. Die Bereitstellung der FIDO2 Cloudservices erfolgt ausschließlich unter Verwendung von proprietären Lizenzen.

Bei der Skalierbarkeit von FIDO2 Servern auf Basis von Bibliotheken ist weniger die Auswahl der Programmiersprache selbst als vielmehr die Gesamtarchitektur der Implementierung maßgeblich. So muss darauf geachtet werden, dass alle verwendeten Komponenten wie z.B. Datenbanken skalieren.

Die Mehrheit der betrachteten FIDO2 Server aus den Kategorien „Stand-alone“ und „module“ haben sowohl vertikale also auch horizontale Skalierung vorgesehen und dokumentiert, indem entweder leistungsstärkere Hardware eingesetzt oder weitere Serverinstanzen hinzugefügt werden, die hinter einem Load Balancer betrieben werden. Zudem werden Größenangaben von bis zu 1000 gleichzeitigen Authentisierungen bzw. Authentisierungen pro Sekunde in einem aus zwei Nodes bestehendem Cluster genannt. Nur in Einzelfällen wurden dazu keine Angaben gemacht. Das bedeutet, dass das Thema Skalierung bei kleinen und mittleren Unternehmen nur eine untergeordnete Rolle spielt. Auch die Anzahl der Benutzer ist kein limitierender Faktor, da alle modernen Datenbanksysteme ausreichend Kapazitäten bieten.

Bei Clouddiensten übernimmt der Anbieter die Skalierung der entsprechenden Systeme, da dies die „Kernkompetenz“ dieser Integrationsart ist bzw. eine gute Skalierung eines der Alleinstellungsmerkmale ist.

4.2.4 Flexibilität

Eigenentwicklungen mit Hilfe von Bibliotheken für eine bestimmte Programmiersprache bieten mit Abstand die höchste Flexibilität, aber vermutlich auch den meisten Aufwand. Im Gegensatz dazu sind die Anpassungsmöglichkeiten von bestehender Software an die individuellen Bedürfnisse von Unternehmen oft eingeschränkt. In diesen Fällen ist man auf den Funktionsumfang des Anbieters angewiesen.

Die Flexibilität in Bezug auf einen potentiellen Wechsel des Anbieters ist generell (außer bei Eigenentwicklungen) eher eingeschränkt. Das hängt im Wesentlichen davon ab, wo die Daten gespeichert sind. Sind diese z.B. in einem Verzeichnisdienst (LDAP) gespeichert, dürfte sich ein Wechsel deutlich einfacher gestalten, sofern die Anbindung jeweils unterstützt wird.

4.2.5 Sicherheitsaspekte

Bei der Auswahl und beim Betrieb eines FIDO2 Servers oder der Entwicklung einer eigenen Softwarelösung sollten Unternehmen dem Thema Sicherheit besondere Beachtung schenken. FIDO2 ist ein sicherer Standard, aber die Implementierung muss korrekt erfolgen, um ein hohes Sicherheitsniveau aufrecht zu erhalten. Dabei ist es zunächst irrelevant, welche Integrationsmöglichkeit zum Einsatz kommt.

Sicherheitsaspekte hängen immer von der Expertise der Entwickler ab, egal ob es Eigenentwicklungen, fertige Software- oder Cloudlösungen sind.

Eigenentwickelte Lösungen können dann anfälliger für Sicherheitslücken sein, wenn sie nicht gründlich getestet werden oder wenn Entwickler nicht über ausreichende Sicherheitskenntnisse verfügen. Das gilt zwar generell für jegliche Software, größere Firmen haben hier aber den Vorteil, dass sie besonders geschulte Mitarbeiter für sicherheitskritische Anwendungen einsetzen können.

Zertifizierungen wie „FIDO certified“, FIPS⁷ (Federal Information Processing Standards) oder Common Criteria⁸ können dazu beitragen, das Vertrauen in die Sicherheit der Authentifizierungssysteme zu stärken und die Risiken von Angriffen und Datenverlusten zu minimieren. Sind diese erwünscht oder gefordert, ist dies bei der Auswahl eines FIDO2 Servers zu berücksichtigen.

Hardware-basierte Sicherheitstechnologien wie Hardware Sicherheitsmodule (HSM) oder Trusted Platform Modules (TPM) können das ohnehin sehr hohe Sicherheitsniveau von FIDO2 zusätzlich verbessern, indem das Schlüsselmaterial innerhalb der Hardwaremodule gespeichert und vor unberechtigtem Zugriff geschützt wird. Allerdings bieten nur ausgewählte Anbieter entsprechenden Support an.

4.2.6 Preisgestaltung und Kosten

Die Preisgestaltung für die FIDO2 Server bzw. Services wird im Regelfall als Betriebsgeheimnis behandelt. Sofern nicht nur Open Source Komponenten eingesetzt werden, fallen mitunter erhebliche jährliche Lizenzgebühren für die Nutzung eines kommerziellen FIDO2 Servers bzw. Services an. Hierbei existiert eine enorme Bandbreite, die von minimal 56 € für 100 Nutzer pro Jahr für ein bestimmtes „FIDO-as-a-Service“ Angebot bis hin zu 1,4 Mio. € für die Nutzung eines FIDO2 Servers mit 100.000 Nutzer pro Jahr reicht.

Die Höhe der voraussichtlichen Kosten beim Einsatz unterschiedlicher FIDO2 Lösungen ist schwer einzuschätzen. Während bei der Verwendung von Bibliotheken der Entwicklungsaufwand finanziell den größten Anteil einnimmt und dafür die Beschaffungskosten entfallen, ist bei den anderen Integrationsmöglichkeiten das Gegenteil der Fall. Hier wird lediglich für die Anschaffung, für Updates und ggf. für Support bezahlt. Eine Ausnahme bilden Cloudlösungen. Hier fallen zwar keine initialen Ausgaben, dafür Kosten in bestimmten Intervallen an.

4.2.7 Interoperabilität und Integration in bestehende Infrastruktur

Die Integration von FIDO2 in eine bestehende Infrastruktur kann auf verschiedene Weise erfolgen, je nach Art des vorhandenen Systems und abhängig von den spezifischen Anforderungen des Webseitenbetreibers bzw. des Unternehmens. Im einfachsten Fall wird bereits ein Identity and Access Management System (IAM) verwendet, das FIDO2 unterstützt oder das über Plugins erweiterbar ist, so dass diese Funktionalität nur aktiviert (und natürlich getestet) werden muss.

Vor der eigentlichen Integration steht die sorgfältige Planung. So sollte zunächst geklärt werden, ob FIDO2 als alleinige Authentisierungsmethode, parallel zu Benutzername/Passwort oder als zweiter Faktor eingesetzt werden soll. Zu beachten ist, dass Nutzer den Umgang mit Benutzernamen/Passwort kennen, während der Einsatz von FIDO2 für die meisten neu sein dürfte. Auf eine benutzerfreundliche Umsetzung und verständliche Dokumentation ist daher zu achten. Zudem ist es sinnvoll, die Vor- und Nachteile der neuen Technologie herauszustellen, Nutzende proaktiv auf die neue Authentisierungsmöglichkeit hinzuweisen und bei der Umstellung geeignet zu unterstützen.

Sind die Benutzerdaten bereits in einem Verzeichnisdienst wie z.B. LDAP vorhanden, lohnt es sich, bei der Anschaffung eines FIDO2 Servers darauf zu achten, dass eine direkte LDAP-Anbindung möglich ist. Die Marktsichtung lieferte hier keine klaren Ergebnisse, da viele Hersteller diesbezüglich keine Angaben gemacht haben. Bei FIDO2 Bibliotheken ist eine Anbindung an einen Verzeichnisdienst designbedingt nicht

⁷ <https://www.nist.gov/itl/publications-0/federal-information-processing-standards-fips>

⁸ <https://www.commoncriteriaportal.org>

gegeben. Den Ergebnissen der technischen Analyse zufolge war eine Anbindung an einen Verzeichnisdienst bei den anderen Integrationsarten mehrheitlich möglich.

Die Interoperabilität mit bestehender Infrastruktur hängt stark von der Unterstützung standardisierter Schnittstellen wie z.B. OpenID Connect (OIDC) oder Security Assertion Markup Language (SAML) und damit von der ausgewählten Integrationsmöglichkeit ab. Ähnlich wie bei Verzeichnisdiensten ist der Support von Schnittstellen bei FIDO2 Bibliotheken nicht gegeben. Die Marktanalyse lieferte bei den Stand-alone Servern in dieser Hinsicht nur wenige Informationen. Von den im Rahmen der technischen Analyse getesteten FIDO2 Servern unterstützte jedoch die Mehrheit neben REST auch OpenID Connect bzw. SAML. Während modulare FIDO2 Server durchgängig standardisierte Schnittstellenlösungen anbieten, ist der Support bei Cloudservices in diesem Bereich oft eingeschränkt.

Webseitenbetreiber, die FIDO2 bei ein oder mehreren Webseiten einführen möchten, stehen vor der Herausforderung, dass eine möglichst umfangreiche Kompatibilität mit gängigen Authenticators gewährleistet werden sollte. Problematisch ist, dass entsprechende Tests nur mit passender Hardware (Authenticator) zu bewerkstelligen sind, was u.U. eine hohe finanzielle Belastung darstellt. Wenn sowohl auf Server- als auch auf Clientseite nur von der FIDO Alliance zertifizierte Produkte verwendet werden, sollte (theoretisch) ein reibungsloser Ablauf gewährleistet sein.

4.2.8 Referenzen

Die Beurteilung eines Produkts kann auch anhand seiner Referenzen, also des Kundenstamms, erfolgen. Die Nutzung eines bestimmten FIDO2 Servers durch große Unternehmen kann z.B. auf eine gute Skalierbarkeit hindeuten.

Die folgenden Angaben basieren im Wesentlichen auf den Erkenntnissen der Marktsichtung. Für die Bibliotheken lassen sich die Referenzen indirekt über den „Dependency graph“ der Rubrik „Insight“ auf github.com ermitteln. So finden sich dort die Open Source Projekte, die eine bestimmte FIDO2 Bibliothek als Abhängigkeit angeben. Beispielsweise gibt es eine Reimplementierung eines Discord Backends, ein Ticketsystem für Veranstaltungen, einen Enterprise VPN Server sowie eine Plattform für UI Komponenten.

Bei den Stand-alone Servern werden neben Anwendern im behördlichen Umfeld (z.B. in den USA und Korea) auch Banken und Versicherungen, Industrieunternehmen und Telekommunikationsanbieter in USA, Asien und Europa genannt.

Als Referenzen bei den modularen FIDO2 Servern finden sich ebenfalls Telekommunikationsunternehmen, Banken sowie Unternehmen in der Verteidigungsindustrie, Energiewirtschaft und im Gesundheitswesen.

Für die FIDO2 Cloudservices werden wenige Referenzen explizit genannt. Lediglich ein Anbieter verweist auf Kunden in Japan und Taiwan. Weitere Referenzen sind nur nach Unterzeichnung eines NDAs zugänglich.

4.2.9 Zusammenfassung

Für einen schnellen Überblick über die Ergebnisse aus den vorherigen Kapiteln werden diese in Tabelle 24 stichpunktartig zusammengefasst. In Tabelle 25 sind die wichtigsten Erkenntnisse nach Integrationsart gegliedert dargestellt.

Kapitel	Zusammenfassung
Aufwand der Integration	Sehr unterschiedlich, von wenigen Stunden bis zu mehreren Tagen Abhängig vom Anwendungsfall Zum Teil zusätzliche organisatorische Hürden
Konfigurierbarkeit	Ebenfalls sehr heterogen Unterschiedlicher Umfang von Konfigurationsoptionen, von minimalen Einstellungsmöglichkeiten bis hin zu komplexen Policy Managern
Funktionsumfang	Filterung nach AAGUID muss bei allen Bibliotheken selbst implementiert werden, bei den anderen FIDO2 Servern ist die Funktionalität häufig vorhanden Bibliotheken haben im Regelfall den Status „FIDO Conformant“, fast alle anderen FIDO2 Server sind von der FIDO-Allianz zertifiziert Skalierung ist fast immer vorgesehen (außer bei Bibliotheken) und sollte in der Regel kein Problem darstellen
Flexibilität	Höchste Flexibilität bei Bibliotheken Gefahr der Abhängigkeit von kommerziellen Anbietern
Sicherheitsaspekte	Müssen bei Eigenentwicklungen selbst berücksichtigt werden Vorhandene Zertifizierungen können Vertrauen schaffen Umfassende Tests sind unabdingbar
Kosten	Generell schwer einzuschätzen bzw. abhängig vom geplanten Funktionsumfang Bei Eigenentwicklungen mit Open Source Komponenten „nur“ die Entwicklungskosten Preise bei proprietären Anbietern schwer in Erfahrung zu bringen
Schnittstellen	Sollten bereits bei der Planung berücksichtigt werden Anbindungen an IAM und Verzeichnisdienste sind bei Bibliotheken selbst zu implementieren, bei den anderen FIDO2 Servern sind die Integrationsmöglichkeiten unterschiedlich ausgeprägt
Referenzen	Bibliotheken werden meistens für kleinere Open Source Projekte genutzt Bei den anderen Integrationsarten finden sich neben Anwendern im behördlichen Umfeld v.a. Banken, Versicherungen und Telekommunikationsanbieter

Tabelle 24: Inhaltliche Zusammenfassung der Ergebnisse

	<i>Bibliothek</i>	<i>Stand-alone</i>	<i>Module</i>	<i>Cloud</i>
Aufwand der Installation	Eher einfach	Aufwendig	Eher einfach	Keine
Konfigurierbarkeit	Einfach	Eher aufwendig	Eher aufwendig	Eher einfach
Funktionsumfang				
a) AAGUID Filterung	Nicht vorgesehen	Meistens möglich		Meistens nicht möglich
b) Unterstützte Authenticators	Device bound Passkeys und Synced Passkeys			
c) WebAuthn Level	Meistens Level 2			
d) Metadata-Service	Muss implementiert werden	Mehrheitlich vorhanden		Eher selten
Sicherheitsaspekte				
a) Allgemein	Verantwortung liegt bei den Entwicklern	Verantwortung liegt bei den Anbietern		
b) Zertifizierungen	In der Regel „FIDO Conformant“	In der Regel FIDO Certified	In der Regel FIDO Certified ⁹	In der Regel FIDO Certified
Kosten	Entwicklungskosten	Anbieter sehr zurückhaltend, verbindliche Preise gibt es häufig nur unter NDA. Erhebliche Unterschiede zwischen einzelnen Produkten.		
Skalierung	Verantwortung liegt bei den Entwicklern bzw. Webseitenbetreibern	Ist bei allen untersuchten Anbietern vorgesehen (horizontal und vertikal).		
Flexibilität	Sehr hoch	Begrenzt	Begrenzt	Sehr begrenzt
Interoperabilität und Integration in bestehende Infrastruktur				
a) Protokolle	Keine	REST, OpenID Connect und SAML		
b) IAM	Keine	Anbindung meistens möglich	Anbindung immer möglich	Anbindung zum Teil möglich
c) Verzeichnisdienste	Keine	Anbindung meistens möglich		Anbindung meistens nicht möglich
Referenzen	Open Source Projekte	Großkunden wie Banken, Versicherungen und Telekommunikationsanbieter		

Tabelle 25: Zusammenfassung der Ergebnisse nach Integrationsart

⁹ In Ausnahmefällen wurde die FIPS 140 Konformität angestrebt.

Wie aus den vorherigen Kapiteln ersichtlich, hat jede Integrationsmöglichkeit ihre individuellen Vor- und Nachteile. Tabelle 26 fasst die wichtigsten Punkte noch einmal zusammen.

	Vorteile	Nachteile
Bibliothek	Maximale Freiheit bei der Entwicklung einer maßgeschneiderten Lösung Leichtere Einbindung in bestehende, eigene Lösungen Geringere Hardwareanforderungen Bibliotheken werden (in der Regel) von Experten auf diesem Gebiet entwickelt und dienen genau einer Aufgabe ("Do One Thing And Do It Well") Es ist leichter, automatisierte Tests (mit) zu entwickeln.	Höherer Zeitaufwand bei der Realisierung bis zur fertigen Lösung Bei Eigenentwicklungen ist man auf die Existenz einer Bibliothek in einer bestimmten Programmiersprache angewiesen (entweder für die Integration in bestehenden Code oder weil sonst die entsprechende Expertise fehlt).
Stand-alone	Gesamtpaket, das die volle Funktionalität beinhaltet Voller Zugriff auf Logdateien u.ä. Support bei kommerziellen Lösungen Anbindungsmöglichkeiten an einen Verzeichnisdienst sowie Schnittstellen wie z.B. OpenID Connect und SAML meist vorhanden	Je nach Produkt hoher Installations- und Konfigurationsaufwand Je nach Produkt hohe Hardwareanforderungen In der Regel keine oder geringe Anpassungsmöglichkeiten
Module	Möglichkeit, FIDO2 im Rahmen einer IAM Lösung zu verwenden Voller Zugriff auf Logdateien u.ä. Anbindungsmöglichkeiten an einen Verzeichnisdienst sowie Schnittstellen wie z.B. OpenID Connect und SAML immer vorhanden	Je nach Produkt hoher Konfigurationsaufwand In der Regel keine oder geringe Anpassungsmöglichkeiten
Cloud	Keine Entwicklung und Installation notwendig Gute Skalierbarkeit: Cloudservices ermöglichen eine einfache Skalierung von Ressourcen (je nach Anforderungen können schnell zusätzliche Rechenleistung, Speicher oder andere Ressourcen hinzugefügt oder reduziert werden, ohne physische Hardware kaufen oder verwalten zu müssen) Je nach Vertragsmodell muss nur für die Ressourcen bezahlt werden, die tatsächlich genutzt werden	Kein Zugriff auf Logdateien. Im Fehlerfall ist keine detaillierte Fehleranalyse möglich. Abhängigkeit von einem Anbieter Ggf. Datenschutzprobleme, wenn die Daten auf Servern außerhalb der EU gespeichert werden

Tabelle 26: Vor- und Nachteile der vier Integrationsmöglichkeiten

4.3 Empfehlung

Die Einführung einer neuen Technologie in eine bestehende Infrastruktur sollte gut geplant werden, um die Verfügbarkeit des laufenden Betriebs nicht zu beeinträchtigen und um für zukünftige Entwicklungen gewappnet zu sein. Im Falle der Integration eines FIDO2 Servers ist der erste und wegweisende Schritt die Festlegung auf eine geeignete Integrationsart. Hierfür können die Informationen aus vorangegangenen Kapiteln herangezogen werden.

Natürlich ist die Entscheidungsfindung in der Praxis deutlich komplexer, da eine Vielzahl individueller Faktoren zu berücksichtigen sind und auch – zumindest in größeren Unternehmen – mehrere Personen bzw. Abteilungen daran beteiligt sind und auch beteiligt werden sollten.

Nachdem die Integrationsart festgelegt wurde, gilt es zu klären, auf welcher Plattform der FIDO2 Server laufen soll. Hier stellt sich zunächst die Frage nach dem Betriebssystem (z.B. Linux oder Windows), aber auch nach der Art des Deployments, d.h. ob ein eigener Server („Baremetal“), eine virtuelle Maschine oder Container auf Basis von z.B. Kubernetes zum Einsatz kommen soll. Im Falle einer Eigenentwicklung muss zusätzlich geklärt werden, welche Programmiersprache und welche Bibliothek verwendet werden soll. Ein weiterer vorab zu klärender Aspekt ist die Frage, ob der FIDO2 Server als Open Source vorliegen muss oder ob proprietäre Anwendungen akzeptabel sind.

Bei der Planung sollte der Aspekt der Skalierung von vornherein mitberücksichtigt werden. Die Tests haben jedoch gezeigt, dass dies nur bei einem sehr hohen Besucheraufkommen relevant ist.

Sofern eine Integration in eine bestehende Infrastruktur notwendig ist, müssen entsprechende Überlegungen angestellt werden, die einen reibungslosen Ablauf gewährleisten. Hierfür sollten entsprechende Tests zunächst in einer Testumgebung durchgeführt werden, die die aktuelle Produktivumgebung exakt widerspiegelt. Auch sollten notwendige Migrationspfade vorher ausgiebig getestet werden.

Besonderer Wert sollte auch auf die Kompatibilität mit einer möglichst großen Anzahl an Authenticatoren gelegt werden. Auch hierfür sind umfangreiche Tests notwendig, je nachdem, wie viele Geräte unterstützt werden sollen.

Auch wenn FIDO2 eine sichere und von Hause aus datensparsame Technologie ist, stellen sich für den Betreiber eines FIDO2 Servers dennoch Fragen des Datenschutzes, insbesondere bei Cloudlösungen, deren Rechenzentren sich außerhalb der Europäischen Union befinden. Vor allem wenn Zertifizierungen angestrebt werden, sollte dem Thema Datenschutz von vornherein eine wichtige Bedeutung beigemessen werden. In jedem Fall ist ein Rechenzentrum in Deutschland oder Europa zu bevorzugen.

Nicht nur bei der Entwicklung eines FIDO2 Servers mithilfe einer Bibliothek ist dafür zu sorgen, dass langfristig das benötigte Know-how zum Betreiben eines FIDO2 Servers dem Unternehmen zur Verfügung steht. Schließlich müssen Updates zeitnah eingespielt und notwendige Anpassungen vorgenommen werden. Eine gewisse Ausnahme bilden hier Cloudlösungen, da hier sämtliche Aufgaben in den Händen des Betreibers liegen.

Die soeben beschriebenen Schritte für die Auswahl eines geeigneten FIDO2 Servers lassen sich wie folgt zusammenfassen:

- Festlegung auf eine geeignete Integrationsart
- Festlegung auf eine geeignete Plattform und ggf. Programmiersprache
- Auswahl einer geeigneten Lösung (Open Source oder proprietäre Anwendung)
- Sicherstellung der Skalierung
- Sicherstellung einer möglichen Integration in eine bestehende Infrastruktur
- Sicherstellung der Kompatibilität mit einer möglichst großen Anzahl an gängigen Authenticators

- Beachtung der Datenschutzbestimmungen für das geplante Einsatzgebiet
- Sicherstellung des notwendigen Know-hows für die Einführung und Pflege

Zusammenfassend lässt sich sagen, dass Unternehmen, die FIDO2 nutzen möchten, alle Aspekte der Inbetriebnahme sorgfältig planen sollten, bevor sie sich auf eine Integrationsmöglichkeit bzw. ein konkretes Produkt festlegen. Falls vorhanden, können mit Hilfe von Testversionen bestimmte Szenarien durchgespielt und so geprüft werden, ob sie die Anforderungen erfüllen. Zusammen mit den oben genannten Informationen sollte dann die Entscheidung erleichtert werden. Eine allgemein gültige Empfehlung für die Auswahl eines geeigneten FIDO2 Servers kann jedoch nicht ausgesprochen werden, da die Wahl von den spezifischen Anforderungen, den Sicherheitsbedenken und anderen Faktoren wie z.B. Datenschutz abhängt.